

МИНИСТЕРСТВО НАУКИ И ВЫСШЕГО ОБРАЗОВАНИЯ
РОССИЙСКОЙ ФЕДЕРАЦИИ

Федеральное государственное бюджетное образовательное учреждение
высшего образования
«РЯЗАНСКИЙ ГОСУДАРСТВЕННЫЙ РАДИОТЕХНИЧЕСКИЙ
УНИВЕРСИТЕТ»
имени В.Ф. Уткина
Кафедра «Информационная безопасность»

К защите
Руководитель проекта
Конкин Ю. В.

дата, подпись

**ПОЯСНИТЕЛЬНАЯ ЗАПИСКА
К КУРСОВОЙ РАБОТЕ**

по дисциплине
«Модели угроз и нарушителей безопасности информации объектов
информатизации»

Выполнил студент группы 241
Потапкин И. А.

дата сдачи на проверку, подпись

Руководитель

оценка

дата защиты, подпись

Рязань 2026

Исходные данные на информационную систему

1. Цели и задачи ИС

Цель создания:

Автоматизация процессов идентификации нарушителей и ведения единого реестра банов для обеспечения общественной безопасности на спортивных мероприятиях.

Задачи ИС:

1. Централизованный учет стадионов, футбольных клубов и расписания матчей.
2. Ведение реестра болельщиков с их персональными данными.
3. Фиксация фактов нарушений (банов) с привязкой к конкретному болельщику и матчу.
4. Обеспечение оперативного поиска информации о нахождении болельщика в "черном списке".
5. Разграничение доступа к функциям системы в зависимости от роли пользователя.

2. Вид информации

2.1. Общедоступная информация

- Названия стадионов и городов.
- Названия клубов.
- Даты матчей (расписание).
- Статистика нарушений (в обезличенном виде).

2.2. Информация ограниченного доступа

А) Персональные данные

В системе обрабатываются персональные данные следующих субъектов:

- Категории субъектов: Болельщики (физические лица), Сотрудники службы безопасности, Секретариат.
- Объем обрабатываемых ПДн:
- ФИО
- Паспортные данные (серия, номер)
- Контактный телефон
- Категория ПДн: Согласно ФЗ-152, обрабатываемые данные относятся к иным категориям ПДн (не специальным, не биометрическим и не общедоступным).
- Статус субъектов: В системе могут обрабатываться как сотрудники организации (внутренние субъекты), так и граждане (болельщики) — внешние субъекты.

Б) Служебная информация (ДСП)

- Внутренние журналы аудита действий пользователей.
- Служебные заметки службы безопасности (поле нарушение содержит оперативную информацию, не предназначенную для публичного распространения).

3. Архитектурные решения

3.1. Технологии обработки

- СУБД: PostgreSQL— для реляционного хранения данных.
· Язык разработки: PHP
- Клиентская часть: Веб-интерфейс HTML для доступа через браузер.
- Форматы данных: Обмен данными между клиентской и серверной частью осуществляется посредством REST API с использованием формата JSON.

- Протоколы: HTTPS для защищенного соединения.

3.2. Пользователи системы

Роль	Описание	Функции
Администратор ИС	Технический специалист (внутренний)	Управление учетными записями, настройка системы, резервное копирование, мониторинг производительности.
Администратор ИБ	Сотрудник службы безопасности (внутренний)	Просмотр журналов аудита, контроль действий операторов, настройка политик паролей
Оператор (Секретариат)	Сотрудник лиги (внутренний)	Ввод и редактирование справочников (стадионы, клубы), формирование расписания матчей.
Оператор (Служба безопасности)	Стюард/Охранник на стадионе (внутренний)	Поиск болельщиков, добавление новых нарушителей, фиксация банов.
Ответственный за функционирование	Начальник смены / Руководитель (внутренний)	Контроль работы системы во время матча, решение нештатных ситуаций, снятие ошибочных банов.
Обслуживающая организация	Внешний подрядчик	Техническое обслуживание серверного оборудования

3.3. Технические средства (ТС)

- АРМ (Автоматизированные рабочие места):

- Персональные компьютеры (офис секретариата, для ответственного за функционирование, для службы безопасности на стадионе)
- Сервер базы данных (Database Server): Выделенный сервер для хранения СУБД.
- ТКС (Телекоммуникационные сети):
- Локальная вычислительная сеть (ЛВС) офиса.
- Беспроводная сеть Wi-Fi на стадионе.

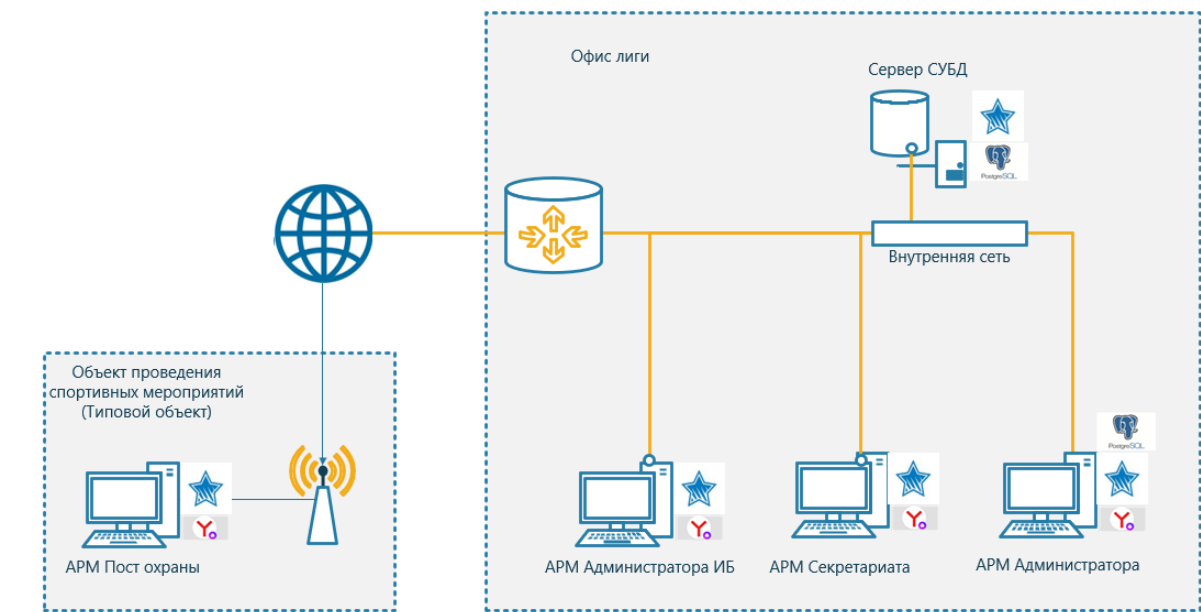
3.4. Программное обеспечение (ПО)

Тип ПО	Наименование / Технология	Назначение
Системное ПО	Astra Linux 1.7	Операционная система для серверов.
Прикладное ПО	Веб-приложение "Бан-ID" (PHP)	Интерфейс для пользователей (секретари, охрана).
	СУБД PostgreSQL	Хранение данных.

3.5. Выбор архитектуры

Для данной ИС выбрана распределенная клиент-серверная архитектура

4. Структурная схема



	Astra linux 1.7
	Яндекс Браузер
	PostgreSQL

Публичное акционерное общество «Спортивные технологии»

УТВЕРЖДАЮ

Генеральный директор

ПАО «Спортивные технологии»

— _____ А.А. Иванов

М.П.

« ____ » _____ 2026 г.

МОДЕЛЬ УГРОЗ

безопасности информации, обрабатываемой в информационной системе
«Бан-ID»

г. Рязань 2026

Оглавление

1 Перечень принятых сокращений	10
2 Термины и их определения	11
3 Общие положения	11
3.1 Назначение и область действия документа	11
3.2 Нормативные правовые акты, методические документы, национальные стандарты, используемые для оценки угроз безопасности информации и разработки модели угроз	12
3.3 Наименование обладателя информации, заказчика, оператора ИС «Бан-ID» ...	14
3.4 Подразделения, должностные лица, ответственные за обеспечение защиты информации (безопасности) ИС «Бан-ID»	14
3.5 Наименование организации, привлекаемой для разработки модели угроз безопасности информации	15
4 Описание информационной системы и ее характеристика как объекта защиты	15
4.1 Общие сведения об информационной системе	15
4.2 Класс защищенности, категория значимости систем и сетей, уровень защищенности персональных данных	16
4.3 Назначение, задачи (функции) информационной системы, состав обрабатываемой информации и ее правовой режим	17
4.4 Основные процессы (бизнес-процессы) оператора, для обеспечения которых создается ИС «Бан-ID»	19
4.5 Состав и архитектура ИС «Бан-ID»	19
4.6 Описание групп внешних и внутренних пользователей системы, уровней их полномочий и типов доступа	21
5. Возможные негативные последствия от реализации (возникновения) угроз безопасности информации	23
6 Возможные объекты воздействия угроз безопасности информации	26
7 Источники угроз безопасности информации	32
7.1 Характеристика нарушителей, которые могут являться источниками угроз безопасности информации, и возможные цели реализации ими угроз безопасности информации	32
7.2 Категории актуальных нарушителей, которые могут являться источниками угроз безопасности информации	36

7.3 Описание возможностей нарушителей по реализации ими угроз безопасности применительно к назначению, составу и архитектуре системы	38
7.4 Возможность сговора	40
7.5 Возможные цели реализации угроз безопасности информации.....	40
8 Способы реализации (возникновения) угроз безопасности информации.....	44
9 Актуальные угрозы безопасности информации.....	58
9.1 Перечень возможных (вероятных) угроз безопасности информации для соответствующих способов их реализации и уровней возможностей нарушителей	58
9.2 Описание возможных сценариев реализации угроз безопасности информации	76
9.3 Выводы об актуальности угроз безопасности информации.....	83
10 Применение средств криптографической защиты информации	119
10.1 Определение актуальности использования СКЗИ для обеспечения безопасности персональных данных	119
10.2 Определение актуальности угроз, нейтрализующихся только с помощью СКЗИ	121
11 Выводы	136

1 Перечень принятых сокращений

АРМ Автоматизированное рабочее место

БД База данных

ИС Информационная система

КЗ Контролируемая зона

ПДн Персональные данные

ПО Программное обеспечение

СЗИ Система (средства) защиты информации

СКЗИ Средства криптографической защиты информации

СУБД Система управления базами данных

СФ Среда функционирования СКЗИ

УБИ Угроза безопасности информации

2 Термины и их определения

В настоящей модели угроз используются следующие термины с соответствующими определениями:

Автоматизированная система — система, состоящая из комплекса средств автоматизации, реализующего информационную технологию выполнения установленных функций, и персонала, обеспечивающего его функционирование.

Безопасность информации — состояние защищённости информации, характеризующееся способностью пользователей, технических средств и информационных технологий обеспечить конфиденциальность, целостность и доступность информации при обработке в автоматизированных системах.

Бан (бан-лист) — перечень болельщиков, которым временно запрещен доступ на спортивные мероприятия в связи с допущенными нарушениями.

Информационная система — совокупность содержащейся в базах данных информации и обеспечивающих ее обработку информационных технологий и технических средств.

Конфиденциальность информации — обязательное для выполнения лицом, получившим доступ к определенной информации, требование не передавать такую информацию третьим лицам без согласия ее обладателя.

Персональные данные — любая информация, относящаяся к прямо или косвенно определенному или определяемому физическому лицу (субъекту персональных данных).

3 Общие положения

3.1 Назначение и область действия документа

Настоящая Модель угроз безопасности информации, обрабатываемой в автоматизированной системе «Бан-ID» (далее — **Модель угроз**) разработана

в целях определения угроз безопасности информации, реализация которых может привести к нарушению безопасности информации при ее обработке в информационной системе «Бан-ID» (далее — ИС «Бан-ID»).

Модель угроз содержит систематизированный перечень угроз безопасности информации ИС «Бан-ID». Эти угрозы обусловлены преднамеренными или непреднамеренными действиями физических лиц или организаций, создающими условия (предпосылки) для нарушения безопасности информации.

На основании Модели угроз решаются следующие задачи:

а) разработка системы защиты информации ИС «Бан-ID», обеспечивающей нейтрализацию предполагаемых угроз с использованием методов и способов защиты информации, предусмотренных для установленного класса защищенности ИС «Бан-ID»;

б) контроль эффективности защиты информации, обрабатываемой в ИС «Бан-ID».

3.2 Нормативные правовые акты, методические документы, национальные стандарты, используемые для оценки угроз безопасности информации и разработки модели угроз

При разработке Модели угроз учитывалось действующее законодательство, нормативные правовые акты и методические документы ФСТЭК России, в которых регламентируются вопросы разработки модели угроз безопасности информации, применимые положения национальных стандартов и иных документов (источников), в том числе:

а) Приказ ФСТЭК России от 11.04.2025 № 117 «Об утверждении Требований о защите информации, содержащейся в государственных информационных системах, иных информационных системах государственных органов, государственных унитарных предприятий, государственных учреждений»;

б) Федеральный закон от 27.07.2006 г. № 149-ФЗ «Об информации, информационных технологиях и о защите информации»;

в) Федеральный закон от 27.07.2006 г. № 152-ФЗ «О персональных данных»;

г) «Методический документ. Методика оценки угроз безопасности информации», утвержден ФСТЭК России 05.02.2021;

д) Указ Президента Российской Федерации от 17.03.2008 г. № 351 «О мерах по обеспечению информационной безопасности Российской Федерации при использовании информационно-телекоммуникационных сетей международного информационного обмена» (ред. от 22.05.2015);

е) Постановление Правительства Российской Федерации от 01.11.2012 г. № 1119 «Об утверждении требований к защите персональных данных при их обработке в информационных системах персональных данных»;

ж) Приказ ФСТЭК России от 18.02.2013 г. № 21 «Об утверждении состава и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных» (ред. от 23.03.2017);

з) Приказ ФСБ России от 10.07.2014 № 378 «Состав и содержание организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных с использованием средств криптографической защиты информации, необходимых для выполнения установленных Правительством Российской Федерации требований к защите персональных данных для каждого из уровней защищённости»;

и) Методические рекомендации по разработке нормативных правовых актов, определяющих угрозы безопасности персональных данных, актуальные при обработке персональных данных в информационных

системах персональных данных, эксплуатируемых при осуществлении соответствующих видов деятельности, утвержден руководством 8 Центра ФСБ России от 31.03.2015 № 149/7/2/6-432;

к) Общий перечень угроз безопасности информации, содержащийся в банке данных угроз безопасности информации (информационное сообщение ФСТЭК России «О банке данных угроз безопасности информации» от 6 марта 2015 г. № 240/22/879) (bdu.fstec.ru).

ИС «Бан-ID» создается на основании следующих документов:

а) Приказ генерального директора ООО «Спортивные технологии» от 07.02.2026 г. № 152 «О создании информационной системы учета нарушителей порядка на спортивных мероприятиях»;

б) Распоряжение Департамента спорта РФ от 06.02.2026 г. № 149 «О внедрении системы «Бан-ID» на подведомственных стадионах».

3.3 Наименование обладателя информации, заказчика, оператора ИС «Бан-ID»

Обладатель информации: ООО «Спортивные технологии»

Заказчик ИС «Бан-ID»: Департамент спорта Рязанской области

Оператор ИС «Бан-ID»: ООО «Спортивные технологии»

3.4 Подразделения, должностные лица, ответственные за обеспечение защиты информации (безопасности) ИС «Бан-ID»

Обеспечение безопасности ИС «Бан-ID» осуществляется:

- На организационном уровне: Руководителем службы информационной безопасности ООО «Спортивные технологии» (назначается приказом).

- На техническом уровне: Системным администратором ИС «Бан-ID» (назначается приказом).

- Контроль и аудит: Внутренняя служба безопасности организации.

3.5 Наименование организации, привлекаемой для разработки модели угроз безопасности информации

В соответствии с Договором № 5485 от 21.01.2026 г. разработка настоящей Модели угроз осуществляется ООО «Спортивные технологии».

4 Описание информационной системы и ее характеристика как объекта защиты

4.1 Общие сведения об информационной системе

Полное наименование информационной системы: Информационная система учета нарушений и бан-листа болельщиков «Бан-ID».

Сокращенное наименование информационной системы: ИС «Бан-ID».

Оператор информационной системы: ООО «Спортивные технологии»

Тип объекта информатизации: Автоматизированные рабочие места (АРМ) пользователей (стационарные ПК), серверное оборудование в ЦОД, имеющие подключение к сетям общего пользования (Интернет) и сетям международного информационного обмена.

Расположение объектов информатизации:

- АРМ секретариата и администраторов — в офисе Оператора по следующему адресу: 390000, г. Рязань, ул. Ленина, д.1.
- АРМ службы безопасности — на стационарных постах охраны стадионов (внутри помещений).
- Серверная часть (ЦОД) — размещается в защищенном центре обработки данных в офисе Оператора

Граница контролируемой зоны (КЗ): ограждающие конструкции помещений, в которых расположены АРМ и серверное оборудование.

Физический доступ в помещения с АРМ ограничен системой контроля доступа (СКУД) или входными замками. На серверах используется сертифицированное системное и прикладное ПО.

На основании «Акта определения уровня защищенности персональных данных» для ИС «Бан-ID» определен 3-й уровень защищенности персональных данных.

4.2 Класс защищенности, категория значимости систем и сетей, уровень защищенности персональных данных

ИС «Бан-ID» имеет следующие характеристики:

а) региональный масштаб (охватывает стадионы и клубы в пределах региона);

б) средний уровень значимости информации (нарушение целостности или доступности может повлиять на безопасность на мероприятии);

в) актуальны угрозы 3-го типа (не связанные с наличием недокументированных возможностей в системном и прикладном ПО, но предполагающие наличие у нарушителя базовых возможностей);

г) обрабатывает персональные данные (ПДн) субъектов, не являющихся сотрудниками оператора (болельщики);

д) объем обрабатываемых ПДн — менее 100 000 субъектов;

е) категории обрабатываемых ПДн: иные (ФИО, паспортные данные, телефон, сведения о нарушениях).

В соответствии с требованиями к защите персональных данных при их обработке в информационных системах персональных данных, утвержденными постановлением Правительства Российской Федерации от 01.11.2012 № 1119, установлена необходимость обеспечения 3-го уровня защищенности персональных данных.

Обоснование: Система обрабатывает иные категории персональных данных ограниченного доступа, включая сведения о фактах нарушения правил посещения спортивных мероприятий, но не обрабатывает биометрические ПДн и не взаимодействует с государственными системами в критическом масштабе.

4.3 Назначение, задачи (функции) информационной системы, состав обрабатываемой информации и ее правовой режим

Цель создания ИС «Бан-ID»: Обеспечение общественной безопасности на спортивных мероприятиях путем централизованного учета болельщиков-нарушителей и автоматизации процессов наложения и проверки банов.

Задачи ИС «Бан-ID»:

1. Централизованное хранение справочной информации о стадионах, клубах и расписании матчей.
2. Ведение реестра болельщиков с их персональными и паспортными данными.
3. Фиксация фактов нарушений (банов) с привязкой к конкретному матчу, болельщику и времени.
4. Оперативный поиск болельщиков в "черном списке" при входе на стадион.
5. Разграничение прав доступа пользователей (администратор, секретариат, служба безопасности).

Функции ИС «Бан-ID»:

1. Ведение базы стадионов (добавление, редактирование, удаление).
2. Ведение базы клубов (привязка к стадиону).
3. Формирование расписания матчей (с проверкой уникальности и непротиворечивости).

4. Регистрация болельщиков (с контролем уникальности по паспорту).
5. Поиск болельщика по ФИО или паспорту.
6. Добавление записи о бане (выбор матча, выбор болельщика, описание нарушения).
7. Формирование отчетов по бан-листу (за период, по стадиону, по типу нарушения).

Состав обрабатываемой информации и ее правовой режим представлены в таблице 1.

Таблица 1 — Состав обрабатываемой информации и ее правовой режим

№ п/п	Категория информации	Правовой режим	Основание
1. Общедоступная информация			
1.1	Названия стадионов, городов, вместимость	Общедоступная информация	ст. 7 ФЗ-149
1.2	Названия клубов	Общедоступная информация	ст. 7 ФЗ-149
1.3	Расписание матчей (дата, участники)	Общедоступная информация	ст. 7 ФЗ-149
2. Персональные данные (иные категории)			
2.1	ФИО болельщика	Персональные данные (иные)	п.1 ст.3 152-ФЗ
2.2	Паспортные данные (серия, номер)	Персональные данные (иные) — конфиденциальная информация	п.1 ст.3 152-ФЗ; п. 5 Постановления № 1119
2.3	Номер телефона	Персональные данные (иные)	п.1 ст.3 152-ФЗ
3. Служебная информация ограниченного доступа			
3.1	Описание нарушения (текст инцидента)	Служебная тайна / ДСП (внутреннее использование)	п. 3.3 Перечня сведений конфиденциального характера (Указ Президента № 188)

3.2	Логи аудита действий пользователей	Служебная информация	п. 3.8 Перечня
-----	------------------------------------	----------------------	----------------

4.4 Основные процессы (бизнес-процессы) оператора, для обеспечения которых создается ИС «Бан-ID»

Создаваемая система должна обеспечить автоматизированную поддержку следующих технологических процессов:

- а) Организация матча: внесение в расписание информации о матче (клубы, стадион, дата);
- б) Регистрация болельщика: занесение данных о новом посетителе (ФИО, паспорт, телефон) с проверкой на дублирование;
- в) Контроль доступа (пропускной режим): оперативная проверка болельщика по бан-листу на стадионе (по паспорту или ФИО);
- г) Фиксация инцидента: создание записи в журнале банов службой безопасности с указанием нарушения;
- д) Формирование отчетности: подготовка сводок по забаненным болельщикам для дисциплинарного комитета;
- е) Аудит: автоматическая запись всех критических действий пользователей (вход, создание бана, удаление бана, изменение данных).

4.5 Состав и архитектура ИС «Бан-ID»

ИС «Бан-ID» представляет собой клиент-серверную трехуровневую информационную систему (уровень клиента — уровень приложений — уровень данных).

Система функционирует на базе информационно-телекоммуникационной инфраструктуры Центра обработки данных (ЦОД) и имеет подключение к сети «Интернет» для обеспечения взаимодействия территориально удаленных сегментов (стадионы, офис лиги).

Состав сегментов ИС «Бан-ID»:

1. Сегмент офиса Оператора (администрирование):

- АРМ Администратора ИС.
- АРМ Секретариата.
- Сервер баз данных (СУБД PostgreSQL).
- Локальная вычислительная сеть (ЛВС) с выходом в Интернет.

2. Сегмент стадионов (объектовый уровень):

- АРМ Службы безопасности (стационарный ПК на посту охраны).
- Локальная вычислительная сеть (ЛВС) стадиона с выходом в Интернет.

Таблица 2 - Технический состав ИС «Бан-ID»

Компонент	Характеристики / Состав
Сервер БД	ПК: Intel Core i5, , 8 GB RAM, 100 GB SSD. ОС: Astra Linux 1.7. ПО: PostgreSQL 15+.
АРМ Секретариата	ПК: Intel Core i3, 8 GB RAM, SSD. ОС: Astra Linux 1.7. Браузер: Yandex.
АРМ Администратора	ПК аналогичный АРМ Секретариата + средства удаленного управления серверами.
АРМ Службы безопасности	ПК: Intel Core i3, 8 GB RAM, SSD. ОС: Astra Linux 1.7. Браузер: Yandex.

Таблица 3 - Программный состав ИС «Бан-ID»

Тип ПО	Наименование	Назначение
Системное ПО (сервер)	Astra Linux 1.7	Операционная система для серверов
Системное ПО (клиент)	Astra Linux 1.7	ОС для АРМ пользователей
СУБД	PostgreSQL	Хранение данных
Прикладное ПО	Веб-приложение «Бан-ID»	Интерфейс пользователя (доступ через веб-браузер)

4.6 Описание групп внешних и внутренних пользователей системы, уровней их полномочий и типов доступа

Перечень информационных ресурсов ИС «Бан-ID» (объекты доступа):

1. Предметная информация (данные о стадионах, клубах, болельщиках, матчах, банах), хранящаяся в БД и отображаемая на экране.
2. Технологическая информация (пароли, журналы аудита, конфигурационные файлы).
3. Технические средства (АРМ, серверы, сетевое оборудование).
4. Программное обеспечение (ОС, СУБД, прикладное ПО).
5. Каналы связи.

Таблица 4 - Категории лиц, имеющих санкционированный доступ к информационным ресурсам (субъекты доступа)

№ п/п	Роль	Тип пользователя	Описание	Функции	Способ доступа
1	Оператор (Служба безопасности)	Внутренний пользователь	Сотрудник охраны на стационарном посту стадиона (ПК)	Поиск болельщика, добавление нового болельщика, фиксация бана.	Физический доступ к АРМ на стадионе.
2	Оператор (Секретариат)	Внутренний пользователь	Сотрудник лиги (офис)	Ведение справочников (стадионы, клубы), формирование расписания.	Физический доступ к АРМ в офисе
3	Администратор ИС	Внутренний пользователь (эксплуатационный персонал)	Системный администратор	Установка, настройка ПО, резервное копирование,	Физический доступ к серверам

				управление пользователями (создание учетных записей), мониторинг.	
4	Администратор ИБ	Внутренний пользователь (эксплуатационный персонал)	Сотрудник службы безопасности	Управление СЗИ (антивирусы, межсетевые экраны), просмотр журналов аудита, контроль политик паролей.	Физический доступ к АРМ
5	Ответственный за функционирование	Внутренний пользователь	Начальник смены / Руководитель	Принятие решений о снятии ошибочных банов, контроль работы системы в экстренных ситуациях.	Локально (АРМ в офисе)
6	Технический и обслуживающий персонал	Внутренний пользователь (эксплуатационный персонал)	Сотрудник и сторонних организаций (клининг, ремонт техники)	Уборка помещений, ремонт и обслуживание технических средств.	Ограниченный физический доступ (в сопровождении Администратора)

5. Возможные негативные последствия от реализации (возникновения) угроз безопасности информации

Исходными данными для определения негативных последствий от реализации угроз безопасности информации являются:

а) общий перечень угроз безопасности информации, содержащийся в банке данных угроз безопасности информации ФСТЭК России (bdu.fstec.ru), модели угроз безопасности информации, разрабатываемые ФСТЭК России в соответствии с подпунктом 4 пункта 8 Положения о Федеральной службе по техническому и экспортному контролю, утвержденного Указом Президента Российской Федерации от 16 августа 2004 г. № 1085, а также отраслевые (ведомственные, корпоративные) модели угроз безопасности информации;

б) нормативные правовые акты Российской Федерации, в соответствии с которыми создаются и функционируют системы и сети, содержащие в том числе описание назначения, задач (функций) систем и сетей, состав обрабатываемой информации и ее правовой режим;

в) документация на ИС «Бан-ID» (в части сведений о назначении и функциях системы, о составе и архитектуре);

г) технологические карты и регламенты, содержащие описание основных (критических) процессов (бизнес-процессов) оператора (процессы организации матчей, регистрации болельщиков, фиксации банов, формирования отчетности);

д) результаты оценки рисков (ущерба), проведенной оператором информационной системы.

На основе анализа исходных данных определяются событие или группа событий, наступление которых в результате реализации (возникновения) угроз безопасности информации может привести к:

1. нарушению прав граждан;
2. возникновению финансовых, производственных, репутационных или иных рисков (видов ущерба) для обладателя информации, оператора.

Событие или группа событий определяются применительно к нарушению основных (критических) процессов (бизнес-процессов), выполнение которых обеспечивает ИС «Бан-ID», и применительно к нарушению безопасности информации, содержащейся в системе.

В таблице 4 представлены виды ущерба и негативные последствия от реализации угроз безопасности информации, обрабатываемой в ИС «Бан-ID», применительно к нарушению основных процессов, выполнение которых обеспечивает ИС «Бан-ID», и применительно к нарушению свойств безопасности информации, содержащейся в ней.

Таблица 5 — Виды рисков (ущерба) и типовые негативные последствия от реализации угроз безопасности информации

№ п/п	Виды риска (ущерба)	Возможные негативные последствия
У1	Ущерб физическому лицу (болельщику, сотруднику)	Финансовый, иной материальный ущерб физическому лицу (при использовании похищенных персональных данных для мошеннических действий, оформления кредитов и т.п.).

		Нарушение конфиденциальности (утечка) персональных данных болельщика Разглашение персональных данных граждан.
У2	Риски юридическому лицу (Оператору ИС «Бан-ID»)	Нарушение законодательства Российской Федерации. Необходимость дополнительных (незапланированных) затрат на закупку товаров, работ или услуг Нарушение штатного режима функционирования ИС «Бан-ID». Утечка конфиденциальной информации. Потеря репутации перед болельщиками и контролирующими органами. Неспособность выполнения договорных обязательств перед организаторами матчей и лигой. Невозможность решения задач (реализации функций) или снижение эффективности решения задач (реализации функций) по обеспечению безопасности на стадионах. Необходимость изменения (перестроения) внутренних процедур для достижения целей,

		решения задач (реализации функций) ИС «Бан-ID»
УЗ	Ущерб государству в области обеспечения безопасности и правопорядка	Отсутствие доступа уполномоченных органов к актуальному бан-листу, что может привести к допуску на матч лиц, совершивших ранее административные правонарушения. Нарушение законодательства Российской Федерации (в части обеспечения общественной безопасности на спортивных мероприятиях в соответствии с Федеральным законом от 04.12.2007 № 329-ФЗ «О физической культуре и спорте в Российской Федерации»).

6 Возможные объекты воздействия угроз безопасности информации

Исходными данными для определения возможных объектов воздействия являются:

а) общий перечень угроз безопасности информации, содержащейся в банке данных угроз безопасности информации ФСТЭК России (bdu.fstec.ru), модели угроз безопасности информации, разрабатываемые ФСТЭК России в соответствии с подпунктом 4 пункта 8 Положения о Федеральной службе по техническому и экспортному контролю, утвержденного Указом Президента Российской Федерации от 16 августа 2004

г. № 1085, а также отраслевые (ведомственные, корпоративные) модели угроз безопасности информации;

б) описания векторов компьютерных атак, содержащиеся в базах данных и иных источниках, опубликованных в сети «Интернет» (CAPEC, ATT&CK, OWASP, STIX, WASC и др.);

в) документация на ИС «Бан-ID» (в части сведений о составе и архитектуре, о группах пользователей и уровне их полномочий и типах доступа, внешних и внутренних интерфейсах);

г) договоры, соглашения или иные документы, содержащие условия использования информационно-телекоммуникационной инфраструктуры центра обработки данных;

д) негативные последствия от реализации (возникновения) угроз безопасности информации, определенные в разделе 5 настоящей модели угроз в соответствии с документом «Методический документ. Методика оценки угроз безопасности информации».

Возможные объекты воздействия ИС «Бан-ID» указаны в таблице 5.

Таблица 6 — Возможные объекты воздействия

№ п/п	Объект воздействия
1	Информация (данные), содержащаяся в системах и сетях (в том числе защищаемая информация, персональные данные, информация о конфигурации систем и сетей, данные телеметрии, сведения о событиях безопасности и конфигурационные данные)
2	Программно-аппаратные средства обработки и хранения информации (в том числе автоматизированные рабочие места секретариата, службы безопасности и администраторов, сервер баз данных, сервер приложений, сетевое оборудование)

3	Программные средства (в том числе системное и прикладное ПО, включая серверы приложений, веб-приложений, системы управления базами данных)
4	Машинные носители информации, содержащие как защищаемую информацию, так и аутентификационную информацию
5	Телекоммуникационное оборудование (в том числе ПО для управления телекоммуникационным оборудованием)

Объекты воздействия ИС «Бан-ID» и виды воздействия на них в соответствии с определенными в разделе 5 негативными последствиями от реализации (возникновения) угроз безопасности информации представлены в таблице 6.

Таблица 7 — Объекты воздействия ИС «Бан-ID» и виды воздействия на них

Негативные последствия (из таблицы 4)	Объекты воздействия	Виды воздействия
У1. Ущерб физическому лицу (финансовый, иной материальный ущерб физическому лицу; нарушение конфиденциальности (утечка) персональных данных болельщика; разглашение персональных данных граждан)	АРМ	Утечка конфиденциальной информации (персональных данных болельщиков); несанкционированная модификация защищаемой информации; несанкционированный доступ к защищаемой информации

	Системное и прикладное ПО	Несанкционированный доступ к системному и прикладному ПО с целью воздействия на защищаемую информацию; утечка конфиденциальной информации (персональных данных); несанкционированная модификация защищаемой информации
	Телекоммуникационное оборудование	Перехват защищаемой информации; несанкционированная модификация защищаемой информации
	Машинные носители информации	Утечка конфиденциальной информации; несанкционированная модификация защищаемой информации
У2. Риски юридическому лицу (Оператору ИС «Бан- ID») (нарушение законодательства РФ; необходимость дополнительных затрат; нарушение штатного режима	АРМ	Утечка конфиденциальной информации; несанкционированный доступ к защищаемой информации; нарушение функционирования (работоспособности) АРМ (простой)

функционирования ИС; утечка конфиденциальной информации; потеря репутации; неспособность выполнения договорных обязательств; невозможность или снижение эффективности решения задач по обеспечению безопасности на стадионах)		
	Системное и прикладное ПО	Несанкционированный доступ к системному и прикладному ПО с целью воздействия на защищаемую информацию; утечка конфиденциальной информации; отказ в обслуживании (нарушение доступности); несанкционированная модификация (подмена, искажение) защищаемой информации
	Телекоммуникационное оборудование	Перехват защищаемой информации; отказ в обслуживании; нарушение функционирования сетевого оборудования

	Машинные носители информации	Утечка конфиденциальной информации; несанкционированная модификация защищаемой информации; уничтожение или повреждение носителей (потеря данных)
УЗ. Ущерб государству в области обеспечения безопасности и правопорядка (отсутствии доступа уполномоченных органов к актуальному бан-листу; допуск на матч лиц, совершивших административные правонарушения; нарушение законодательства в сфере физической культуры и спорта)	АРМ	Отказ в обслуживании; несанкционированный доступ к защищаемой информации
	Системное и прикладное ПО	Несанкционированная модификация, подмена, искажение защищаемой информации; отказ в обслуживании

	Телекоммуникационное оборудование	Перехват защищаемой информации; отказ в обслуживании
--	-----------------------------------	---

7 Источники угроз безопасности информации

7.1 Характеристика нарушителей, которые могут являться источниками угроз безопасности информации, и возможные цели реализации ими угроз безопасности информации

Исходными данными для определения возможных актуальных нарушителей являются:

а) общий перечень угроз безопасности информации, содержащийся в банке данных угроз безопасности информации ФСТЭК России (bdu.fstec.ru), модели угроз безопасности информации, разрабатываемые ФСТЭК России в соответствии с подпунктом 4 пункта 8 Положения о Федеральной службе по техническому и экспортному контролю, утвержденного Указом Президента Российской Федерации от 16 августа 2004 г. № 1085, а также отраслевые (ведомственные, корпоративные) модели угроз безопасности информации;

б) описания векторов компьютерных атак, содержащихся в базах данных и иных источниках, опубликованных в сети «Интернет» (CAPEC, ATT&CK, OWASP, STIX, WASC и др.);

в) нормативные правовые акты Российской Федерации, в соответствии с которыми создается и функционирует система или сеть, содержащие

описание назначения, задач (функций) систем и сетей, состав обрабатываемой информации и ее правовой режим;

г) документация на ИС «Бан-ID» (в части сведений о назначении и функциях, составе и архитектуре, о группах пользователей и уровне их полномочий и типов доступа);

д) договоры, соглашения или иные документы, содержащие условия использования информационно-телекоммуникационной инфраструктуры центра обработки данных или облачной инфраструктуры поставщика услуг (в части персонала поставщика услуг, имеющего доступ к этой инфраструктуре, его прав и обязанностей, уровня полномочий и типов доступа);

е) результаты оценки ущерба (рисков), проведенной владельцем информации или оператором;

ж) негативные последствия от реализации (возникновения) угроз безопасности информации, определенные в разделе 5 настоящей модели угроз;

з) объекты воздействия угроз безопасности информации и виды воздействия на них, определенные в разделе 6 настоящей модели угроз.

Возможные цели реализации угроз безопасности информации разными видами нарушителей представлены в таблице 8.

Таблица 8 — Возможные цели реализации угроз безопасности информации разными видами нарушителей

№ вида	Виды нарушителей	Возможные цели реализации угроз безопасности информации
1	Преступные группы (криминальные структуры)	Получение финансовой или иной материальной выгоды (продажа базы персональных данных болельщиков на «черном рынке», шантаж

		оператора системы). Желание самореализации (подтверждение статуса).
2	Отдельные физические лица (хакеры)	Получение финансовой или иной материальной выгоды. Любопытство или желание самореализации (подтверждение статуса). Политический или спортивный активизм (взлом с целью дискредитации лиги/клуба).
3	Разработчики программных, программно-аппаратных средств (подрядчики)	Получение конкурентных преимуществ. Получение финансовой или иной материальной выгоды (продажа кода, алгоритмов, информации об уязвимостях). Непреднамеренные, неосторожные или неквалифицированные действия (закладки в коде).
4	Лица, обеспечивающие поставку программных, программно-аппаратных средств	Получение финансовой или иной материальной выгоды. Непреднамеренные, неосторожные или неквалифицированные действия. Получение конкурентных преимуществ.
5	Поставщики вычислительных услуг, услуг связи (хостинг, провайдер)	Получение финансовой или иной материальной выгоды. Непреднамеренные, неосторожные или неквалифицированные действия.

		Получение конкурентных преимуществ.
6	Лица, привлекаемые для установки, настройки, испытаний, пусконаладочных и иных видов работ (системные интеграторы)	Получение финансовой или иной материальной выгоды. Непреднамеренные, неосторожные или неквалифицированные действия. Получение конкурентных преимуществ.
7	Лица, обеспечивающие функционирование системы или обеспечивающие системы оператора (администрация, охрана, уборщики и т.д.)	Получение финансовой или иной материальной выгоды. Непреднамеренные, неосторожные или неквалифицированные действия. Шпионаж (наблюдение за экранами мониторов).
8	Авторизованные пользователи системы (Служба безопасности, Секретариат)	Получение финансовой или иной материальной выгоды (продажа данных о банках). Любопытство или желание самореализации. Месть за ранее совершенные действия (внесение ложных банов, снятие банов с друзей). Непреднамеренные, неосторожные или неквалифицированные действия.
9	Системные администраторы и администраторы безопасности	Получение финансовой или иной материальной выгоды (продажа паспортных данных). Любопытство или желание самореализации. Месть за ранее совершенные действия

		(удаление базы данных, блокировка системы). Непреднамеренные, неосторожные или неквалифицированные действия.
10	Бывшие работники	Получение финансовой или иной материальной выгоды. Месть за ранее совершенные действия (использование сохранённых логинов/паролей для взлома, публикация бан-листов).

7.2 Категории актуальных нарушителей, которые могут являться источниками угроз безопасности информации

Для актуальных нарушителей должны быть определены их категории в зависимости от имеющихся прав и условий по доступу к системе, обусловленных архитектурой и условиями функционирования этой системы, а также от установленных возможностей нарушителей. При этом нарушители подразделяются на две категории:

А) Внутренние нарушители — имеют санкционированный физический или логический доступ к компонентам системы. Внешние нарушители — не имеют прав доступа в контролируемую зону или полномочий по доступу к информационным ресурсам системы.

Б) Виды нарушителя и соответствующие им категории нарушителей представлены в таблице 9.

Таблица 9 — Виды нарушителя и соответствующие им категории нарушителей

№ вида	Виды нарушителя	Категория нарушителя
--------	-----------------	----------------------

1	Преступные группы (криминальные структуры)	Внешний
2	Отдельные физические лица (хакеры)	Внешний
3	Разработчики программных, программно-аппаратных средств	Внутренний (на этапе создания/сопровождения) / Внешний (после передачи системы)
4	Лица, обеспечивающие поставку программных, программно-аппаратных средств	Внешний
5	Поставщики вычислительных услуг, услуг связи	Внутренний
6	Лица, привлекаемые для установки, настройки, испытаний, пусконаладочных и иных видов работ	Внутренний (временный доступ)
7	Лица, обеспечивающие функционирование системы или обеспечивающие системы оператора (администрация, охрана, уборщики и т.д.)	Внутренний (физический доступ)
8	Авторизованные пользователи системы (Служба безопасности, Секретариат)	Внутренний
9	Системные администраторы и администраторы безопасности	Внутренний (привилегированный)
10	Бывшие работники	Внешний

7.3 Описание возможностей нарушителей по реализации ими угроз безопасности применительно к назначению, составу и архитектуре системы

Описание возможностей нарушителей по реализации ими угроз безопасности представлено в таблице 10.

Таблица 10 — Уровни возможностей нарушителей по реализации угроз безопасности информации

№	Уровень возможностей нарушителей	Возможности нарушителей по реализации угроз безопасности информации	Виды нарушителей
Н1	Нарушитель, обладающий базовыми возможностями	Имеет возможность использовать только известные уязвимости, скрипты и общедоступные инструменты. Обладает базовыми компьютерными знаниями на уровне пользователя. Имеет возможность реализации угроз за счет физических воздействий на технические средства при наличии физического доступа к ним.	Отдельные физические лица (хакеры); Лица, обеспечивающие функционирование системы (охрана, уборщики); Бывшие работники.
Н2	Нарушитель, обладающий базовыми повышенными возможностями	Обладает всеми возможностями Н1. Хорошо владеет средствами и инструментами, может вносить в них изменения для повышения эффективности атак. Имеет навыки самостоятельного планирования и реализации сценариев угроз. Обладает практическими знаниями о функционировании ОС и защитных механизмах.	Преступные группы (криминальные структуры); Системные администраторы и администраторы безопасности; Разработчики ПО; Лица, привлекаемые для установки и настройки.

7.4 Возможность сговора

В отношении возможности сговора нарушителей необходимо учитывать:

- а) сговор нарушителей одной категории не ведет к расширению возможностей несанкционированного воздействия на информацию;
- б) вступившие в сговор нарушители разных категорий обладают возможностями, присущими нарушителю более высокой категории, что также не приводит к расширению возможностей несанкционированного воздействия на информацию (например, сговор системного администратора (Н2) и авторизованного пользователя (Н1) расширяет возможности до уровня Н2).

7.5 Возможные цели реализации угроз безопасности информации

Определение актуальных нарушителей, характерных для ИС «Бан-ID», осуществляется на основе предположений о возможных целях (мотивации) нарушителей, а также их возможностях (потенциале) по реализации угроз безопасности информации. Результаты оценки приведены в таблице 11, а перечень актуальных нарушителей — в таблице 12.

Таблица 11 — Оценка актуальности нарушителей

№	Вид нарушителя	Актуальность	Обоснование оценки
1	Преступные группы (криминальные структуры)	Актуален	Способны осуществлять несанкционированный доступ с целью получения персональных данных болельщиков (паспорта, телефоны) для получения финансовой или иной материальной выгоды.

2	Отдельные физические лица (хакеры)	Актуален	Способны осуществлять атаки с целью кражи данных (паспортов), порчи репутации лиги/клуба (раскрытие бан-листов), а также из хулиганских побуждений.
3	Разработчики программных, программно-аппаратных средств	Актуален	Обладают знаниями о топологии, архитектуре и потенциальных уязвимостях системы, что может быть использовано с целью получения финансовой выгоды или внедрения «закладок».
4	Лица, обеспечивающие поставку средств	Не актуален	Поставка оборудования выполняется на основании договоров, включающих гарантийные обязательства. Ценность информации низкая, риски нарушения конфиденциальности на этапе поставки минимальны.
5	Поставщики вычислительных услуг, услуг связи	Актуален	Персонал ЦОД (хостинг-провайдера) имеет физический доступ к серверам, что создает риск кражи резервных копий или прямого копирования файлов баз данных.

6	Лица, привлекаемые для установки, настройки, испытаний	Актуален	Могут внедрить программные закладки или получить несанкционированный доступ к тестовым данным, которые затем могут быть использованы для атаки на продуктивную систему.
7	Лица, обеспечивающие функционирование системы (администрация, охрана, уборщики)	Актуален	Имеют санкционированный физический доступ в помещения, где расположены АРМ, и могут выполнить съем информации или осуществить наблюдение за экранами.
8	Авторизованные пользователи системы (Служба безопасности, Секретариат)	Актуален	Обладая легитимным доступом к базе данных и прикладному ПО, могут скопировать паспортные данные, внести ложные записи о банах («забанить» невиновного) или снять бан с нарушителя за взятку.
9	Системные администраторы и администраторы безопасности	Актуален	Имеют неограниченный доступ ко всем данным и настройкам. Могут отключить журналы аудита, украсть всю базу данных, уничтожить систему,

			подменить служебную информацию.
10	Бывшие работники	Актуален	Обладают сохранёнными учетными данными (паролями) или знаниями об уязвимостях в системе, которые не были изменены после их увольнения. Могут действовать из мести за увольнение.

Таблица 12 — Актуальные виды нарушителей

№	Вид (категория) нарушителя
1	Преступные группы (криминальные структуры)
2	Отдельные физические лица (хакеры)
3	Разработчики программных, программно-аппаратных средств
4	Поставщики вычислительных услуг, услуг связи
5	Лица, привлекаемые для установки, настройки, испытаний и иных видов работ
6	Лица, обеспечивающие функционирование систем или обеспечивающие системы оператора (администрация, охрана, уборщики и т.д.)
7	Авторизованные пользователи систем и сетей (Секретариат, Служба безопасности)
8	Системные администраторы и администраторы безопасности
9	Бывшие работники

8 Способы реализации (возникновения) угроз безопасности информации

Основными способами реализации (возникновения) угроз безопасности информации являются:

- а) использование уязвимостей (уязвимостей кода (программного обеспечения), уязвимостей архитектуры и конфигурации систем и сетей, а также организационных и многофакторных уязвимостей);
- б) внедрение вредоносного программного обеспечения;
- в) использование недеklarированных возможностей программного обеспечения и (или) программно-аппаратных средств;
- г) установка программных и (или) программно-аппаратных закладок в программное обеспечение и (или) программно-аппаратные средства;
- д) формирование и использование скрытых каналов (по времени, по памяти) для передачи конфиденциальных данных;
- е) перехват (измерение) побочных электромагнитных излучений и наводок (далее — ПЭМИН) (других физических полей) для доступа к конфиденциальной информации, содержащейся в аппаратных средствах аутентификации;
- ж) инвазивные способы доступа к конфиденциальной информации, содержащейся в аппаратных средствах аутентификации;
- з) нарушение безопасности при поставках программных, программно-аппаратных средств и (или) услуг по установке, настройке, испытаниям, пусконаладочным работам (в том числе администрированию, обслуживанию);
- и) ошибочные действия в ходе создания и эксплуатации систем и сетей, в том числе при установке, настройке программных и программно-аппаратных средств.

Способы являются актуальными, когда возможности нарушителя позволяют их использовать для реализации угроз безопасности и имеются или созданы условия, при которых такая возможность может быть реализована в отношении объектов воздействия. Одна угроза безопасности информации может быть реализована несколькими способами.

Условием, позволяющим нарушителям использовать способы реализации угроз безопасности информации, является наличие у них возможности доступа к следующим типам интерфейсов объектов воздействия:

а) внешние сетевые интерфейсы, обеспечивающие взаимодействие с сетью «Интернет», смежными (взаимодействующими) системами или сетями (проводные, беспроводные, веб-интерфейсы, интерфейсы удаленного доступа и др.);

б) внутренние сетевые интерфейсы, обеспечивающие взаимодействие (в том числе через промежуточные компоненты) с компонентами систем и сетей, имеющими внешние сетевые интерфейсы (проводные, беспроводные);

в) интерфейсы для пользователей (проводные, беспроводные, веб-интерфейсы, интерфейсы удаленного доступа и др.);

г) интерфейсы для использования съемных машинных носителей информации и периферийного оборудования;

д) интерфейсы для установки, настройки, испытаний, пусконаладочных работ (в том числе администрирования, управления, обслуживания) обеспечения функционирования компонентов систем и сетей;

е) возможность доступа к поставляемым или находящимся на обслуживании, ремонте в сторонних организациях компонентам систем и сетей.

Актуальные способы реализации угроз безопасности информации ИС «Бан-ID» и соответствующие им виды нарушителей и их возможности представлены в таблице 13.

Таблица 13 — Актуальные способы реализации угроз безопасности информации и соответствующие им виды нарушителей и их возможности

№	Вид нарушителя (уровень возможностей)	Категория нарушителя	Объект воздействия	Доступные интерфейсы	Способы реализации
1	Отдельные физические лица (хакеры) (Н1)	Внешний	Информация (данные), содержащаяся в системах и сетях	Внешние сетевые интерфейсы, обеспечивающие взаимодействие с сетью «Интернет»	Внедрение вредоносного программного обеспечения (через уязвимости веб- приложения); Использование уязвимостей (уязвимостей кода веб-приложения, уязвимостей архитектуры и конфигурации сетей)
			Программные средства		Использование уязвимостей

					(уязвимостей кода, уязвимостей архитектуры и конфигурации систем и сетей)
			Телекоммуникационное оборудование		Использование уязвимостей (уязвимостей кода программного обеспечения сетевого оборудования, уязвимостей архитектуры и конфигурации сетей)
2	Преступные группы (криминальные структуры) (H2)	Внешний	Информация (данные), содержащаяся в системах и сетях	Внешние сетевые интерфейсы, обеспечивающие	Внедрение вредоносного программного обеспечения;

				взаимодействие с сетью «Интернет»	Использование уязвимостей (уязвимостей кода, архитектуры и конфигурации)
			Программные средства		Использование уязвимостей (в том числе недокументированных возможностей ПО)
			Машинные носители информации	Интерфейсы для использования съемных машинных носителей информации	Внедрение вредоносного программного обеспечения
3	Разработчики программных, программно-	Внутренний	Программные средства	Интерфейсы для установки, настройки,	Внедрение вредоносного программного

	аппаратных средств (H2)			испытаний, пусконаладочных работ	обеспечения (закладки в коде); Использование уязвимостей (в том числе недекларированных возможностей); Ошибочные действия в ходе создания и эксплуатации систем и сетей
					Установка программных и (или) программно- аппаратных закладок; Ошибочные действия в ходе создания и эксплуатации

			Информация (данные), содержащаяся в системах и сетях		Внедрение вредоносного программного обеспечения; Использование уязвимостей
4	Лица, привлекаемые для установки, настройки, испытаний, пусконаладочных и иных видов работ (системные интеграторы) (Н2)	Внутренний	Программные средства	Интерфейсы для установки, настройки, испытаний	Внедрение вредоносного программного обеспечения (закладки); Использование уязвимостей; Ошибочные действия в ходе создания и эксплуатации
			Программно- аппаратные средства		Установка программных и (или)

			обработки и хранения информации		программно-аппаратных закладок; Ошибочные действия в ходе установки и настройки
			Информация (данные), содержащаяся в системах и сетях		Копирование информации на съемные носители; Использование уязвимостей (уязвимостей архитектуры и конфигурации)
5	Поставщики вычислительных услуг, услуг связи (персонал ЦОД) (Н2)	Внутренний	Информация (данные), содержащаяся в системах и сетях	Интерфейсы для установки, настройки; Интерфейсы для использования	Копирование информации на съемные носители; Внедрение вредоносного

				съемных машинных носителей информации	программного обеспечения; Нарушение безопасности при поставке услуг
			Программно-аппаратные средства обработки и хранения информации	Интерфейсы для установки, настройки	Установка программных и (или) программно-аппаратных закладок; Ошибочные действия в ходе обслуживания
			Телекоммуникационное оборудование	Внешние и внутренние сетевые интерфейсы	Использование уязвимостей (настройки сетевого оборудования); Перехват трафика
6	Лица, обеспечивающие	Внутренний	Программно-аппаратные средства	Интерфейсы для пользователей	Ошибочные действия в ходе эксплуатации;

	функционирование системы (администрация, охрана, уборщики) (Н1)		обработки и хранения информации	(физический доступ к ПК); Интерфейсы для использования съемных машинных носителей информации	Копирование информации на съемные носители; Наблюдение за экранами мониторов
			Машинные носители информации	Интерфейсы для пользователей	Хищение бумажных носителей
7	Авторизованные пользователи системы (Служба безопасности, Секретариат) (Н1)	Внутренний	Информация (данные), содержащаяся в системах и сетях	Интерфейсы для пользователей	Использование уязвимостей; Ошибочные действия в ходе эксплуатации; Копирование информации
			Программные средства		Использование уязвимостей

			Программно-аппаратные средства обработки и хранения информации	Интерфейсы для пользователей; Интерфейсы для использования съемных машинных носителей информации	Копирование информации на съемные носители; Установка нештатного ПО
8	Системные администраторы и администраторы безопасности (Н2)	Внутренний (привилегированный)	Информация (данные), содержащаяся в системах и сетях	Интерфейсы для установки, настройки, администрирования; Интерфейсы для использования съемных машинных носителей информации	Копирование всей базы данных на съемный носитель; Внедрение вредоносного программного обеспечения; Использование уязвимостей (в том числе недекларированных)

					возможностей); Ошибочные действия в ходе администрирования
			Программные средства	Интерфейсы для установки, настройки, администрирования	Установка программных закладок; Использование недекларированных возможностей;
			Программно- аппаратные средства обработки и хранения информации		Установка аппаратных закладок; Нарушение конфигурации средств вычислительной техники; Ошибочные действия

9	Бывшие работники (Н1)	Внешний	Информация (данные), содержащаяся в системах и сетях	Внешние сетевые интерфейсы	Использование уязвимостей; Внедрение вредоносного программного обеспечения
			Программные средства	Внешние сетевые интерфейсы	Использование уязвимостей

9 Актуальные угрозы безопасности информации

9.1 Перечень возможных (вероятных) угроз безопасности информации для соответствующих способов их реализации и уровней возможностей нарушителей

Адаптация перечня угроз предусматривает исключение угроз, непосредственно связанных с информационными технологиями, условиями эксплуатации или структурно-функциональными характеристиками, не свойственными для ИС «Бан-ID».

При адаптации угроз безопасности учитываются следующие особенности, неприменимые по отношению к ИС «Бан-ID»:

- а) использование технологий грид-систем;
- б) использование технологий суперкомпьютерных систем;
- в) использование облачных услуг (серверная часть размещается в ЦОД оператора);
- г) наличие трансграничной передачи данных;
- д) использование хранилищ больших данных;
- е) использование мобильных устройств (АРМ стационарные);
- ж) применение оборудования с числовым программным управлением (ЧПУ), автоматизированной системы управления технологическим процессом, логических контроллеров;
- з) наличие нарушителя с высоким потенциалом (Н3, Н4) — для ИС «Бан-ID» определены нарушители с базовыми (Н1) и базовыми повышенными (Н2) возможностями;

и) иных факторов, не соответствующих архитектуре и условиям функционирования ИС «Бан-ID».

В таблице 14 представлены угрозы, связанные с использованием технологий грид-систем, которые необходимо исключить.

Таблица 14 — Угрозы использования технологий грид-систем

№	Наименование
УБИ.001	Угроза автоматического распространения вредоносного кода в грид-системе
УБИ.002	Угроза агрегирования данных, передаваемых в грид-системе
УБИ.047	Угроза нарушения работоспособности грид-системы при нетипичной сетевой нагрузке
УБИ.081	Угроза несанкционированного доступа к локальному компьютеру через клиента грид-системы
УБИ.110	Угроза перезагрузки грид-системы вычислительными заданиями
УБИ.147	Угроза распространения несанкционированно повышенных прав на всю грид-систему

В таблице 15 представлены угрозы, связанные с использованием технологий суперкомпьютерных систем, которые необходимо исключить.

Таблица 15 — Угрозы, связанные с использованием технологий суперкомпьютерных систем

№	Наименование
УБИ.029	Угроза использования вычислительных ресурсов суперкомпьютера «паразитными» процессами
УБИ.082	Угроза несанкционированного доступа к сегментам вычислительного поля

УБИ.106	Угроза отказа в обслуживании системой хранения данных суперкомпьютера
УБИ.146	Угроза прямого обращения к памяти вычислительного поля суперкомпьютера
УБИ.161	Угроза чрезмерного использования вычислительных ресурсов суперкомпьютера в ходе интенсивного обмена межпроцессорными сообщениями

В таблице 16 представлены угрозы, связанные с использованием облачных услуг, которые необходимо исключить (ввиду размещения ЦОД в офисе Оператора).

Таблица 16 — Угрозы, связанные с использованием облачных услуг

№	Наименование
УБИ.020	Угроза злоупотребления возможностями, предоставленными потребителям облачных услуг
УБИ.021	Угроза злоупотребления доверием потребителей облачных услуг
УБИ.043	Угроза нарушения доступности облачного сервера
УБИ.052	Угроза невозможности миграции образов виртуальных машин из-за несовместимости ПО
УБИ.054	Угроза недобросовестного исполнения обязательств поставщиками облачных услуг
УБИ.055	Угроза незащищенного администрирования облачных услуг
УБИ.056	Угроза некачественного переноса инфраструктуры в облако
УБИ.058	Угроза неконтролируемого роста числа виртуальных машин
УБИ.064	Угроза некорректной реализации политики лицензирования в облаке

УБИ.065	Угроза неопределенности в распределении ответственности между ролями в облаке
УБИ.066	Угроза неопределенности ответственности за обеспечение безопасности в облаке
УБИ.070	Угроза непрерывной модернизации облачной инфраструктуры
УБИ.096	Угроза несогласованности политик безопасности элементов облачной инфраструктуры
УБИ.101	Угроза общедоступности облачной инфраструктуры
УБИ.108	Угроза ошибки обновления гипервизора
УБИ.134	Угроза потери доверия к поставщику облачных услуг
УБИ.135	Угроза потери и утечки данных, обрабатываемых в облаке
УБИ.137	Угроза потери управления облачными ресурсами
УБИ.138	Угроза потери управления собственной инфраструктурой при переносе ее в облако
УБИ.141	Угроза привязки к поставщику облачных услуг
УБИ.142	Угроза приостановки оказания облачных услуг вследствие технических сбоев
УБИ.164	Угроза распространения состояния «отказ в обслуживании» в облачной инфраструктуре

В таблице 17 представлены угрозы, связанные с трансграничной передачей данных, которые необходимо исключить.

Таблица 17 — Угрозы, связанные с трансграничной передачей данных

№	Наименование
УБИ.040	Угроза конфликта юрисдикций различных стран

В таблице 18 представлены угрозы, связанные с использованием мобильных устройств, которые необходимо исключить (АРМ службы безопасности — стационарные ПК).

Таблица 18 — Угрозы, связанные с использованием мобильных устройств

№	Наименование
УБИ.184	Угроза агрегирования данных, обрабатываемых с помощью мобильного устройства
УБИ.199	Угроза перехвата управления мобильного устройства при использовании виртуальных голосовых ассистентов
УБИ.200	Угроза хищения информации с мобильного устройства при использовании виртуальных голосовых ассистентов
УБИ.202	Угроза несанкционированной установки приложений на мобильные устройства

В таблице 19 представлены угрозы, связанные с использованием хранилищ больших данных, которые необходимо исключить.

Таблица 19 — Угрозы, связанные с использованием хранилищ больших данных

№	Наименование
УБИ.038	Угроза исчерпания вычислительных ресурсов хранилища больших данных
УБИ.050	Угроза неверного определения формата входных данных, поступающих в хранилище больших данных
УБИ.057	Угроза неконтролируемого копирования данных внутри хранилища больших данных

УБИ.060	Угроза неконтролируемого уничтожения информации хранилищем больших данных
УБИ.097	Угроза несогласованности правил доступа к большим данным
УБИ.105	Угроза отказа в загрузке входных данных неизвестного формата хранилищем больших данных
УБИ.136	Угроза потери информации вследствие несогласованности работы узлов хранилища больших данных
УБИ.148	Угроза сбоя автоматического управления системой разграничения доступа хранилища больших данных

В таблице 20 представлены угрозы, связанные с использованием оборудования с ЧПУ, АСУ ТП, программируемых логических контроллеров, которые необходимо исключить.

Таблица 20 — Угрозы, связанные с использованием оборудования с ЧПУ, АСУ ТП, ПЛК

№	Наименование
УБИ.107	Угроза отключения контрольных датчиков
УБИ.112	Угроза передачи запрещенных команд на оборудование с числовым программным управлением
УБИ.183	Угроза перехвата управления автоматизированной системой управления технологическими процессами
УБИ.204	Угроза несанкционированного изменения вредоносной программой значений параметров ПЛК
УБИ.206	Угроза отказа в работе оборудования из-за изменения геолокационной информации о нем
УБИ.207	Угроза несанкционированного доступа к параметрам настройки оборудования за счет использования «мастер-кодов»

В таблице 21 представлены угрозы, которые необходимо исключить ввиду отсутствия нарушителя с высоким потенциалом (Н3, Н4) для ИС «Бан-ID».

Таблица 21 — Угрозы, связанные с нарушителем с высоким потенциалом

№	Наименование
УБИ.005	Угроза внедрения вредоносного кода в BIOS
УБИ.010	Угроза выхода процесса за пределы виртуальной машины (при использовании виртуализации)
УБИ.024	Угроза изменения режимов работы аппаратных элементов компьютера
УБИ.027	Угроза искажения вводимой и выводимой на периферийные устройства информации
УБИ.035	Угроза использования слабых криптографических алгоритмов BIOS
УБИ.044	Угроза нарушения изоляции пользовательских данных внутри виртуальной машины
УБИ.045	Угроза нарушения изоляции среды исполнения BIOS
УБИ.046	Угроза нарушения процедуры аутентификации субъектов виртуального информационного взаимодействия
УБИ.048	Угроза нарушения технологии обработки информации путем несанкционированного внесения изменений в образы виртуальных машин
УБИ.049	Угроза нарушения целостности данных кеша
УБИ.075	Угроза несанкционированного доступа к виртуальным каналам передачи

УБИ.076	Угроза несанкционированного доступа к гипервизору из виртуальной машины
УБИ.077	Угроза несанкционированного доступа к данным за пределами зарезервированного адресного пространства
УБИ.078	Угроза несанкционированного доступа к защищаемым виртуальным машинам
УБИ.079	Угроза несанкционированного доступа к защищаемым виртуальным машинам со стороны других виртуальных машин
УБИ.080	Угроза несанкционированного доступа к защищаемым виртуальным устройствам
УБИ.085	Угроза несанкционированного доступа к хранимой в виртуальном пространстве защищаемой информации
УБИ.087	Угроза несанкционированного использования привилегированных функций BIOS
УБИ.092	Угроза несанкционированного удаленного внеполосного доступа к аппаратным средствам
УБИ.210	Угроза нарушения работы информационной системы, вызванного обновлением используемого в ней ПО
УБИ.119	Угроза перехвата управления гипервизором
УБИ.120	Угроза перехвата управления средой виртуализации
УБИ.213	Угроза обхода многофакторной аутентификации

В таблице 22 представлены иные угрозы, которые необходимо исключить ввиду их неприменимости для ИС «Бан-ID».

Таблица 22 — Иные угрозы, которые необходимо исключить

№	Наименование	Примечание
---	--------------	------------

УБИ.094	Угроза несанкционированного управления синхронизацией и состоянием	Не используются технологии управления процессами на основе времени
УБИ.176	Угроза нарушения технологического/производственного процесса из-за временных задержек, вносимых СЗИ	Не применяются системы реального времени
УБИ.181	Угроза перехвата одноразовых паролей в режиме реального времени	Не используются одноразовые пароли
УБИ.215	Угроза несанкционированного доступа к системе при помощи сторонних сервисов	Не используются сторонние легитимные сервисы
УБИ.216	Угроза получения несанкционированного доступа к приложениям, установленным на Smart-картах	Не используются Smart-карты
	Угрозы утечки акустической (речевой) информации	ИС «Бан-ID» не обрабатывает речевую информацию
	Угрозы утечки видовой информации	ИС «Бан-ID» не обрабатывает видеoinформацию
	Угрозы утечки информации по каналам ПЭМИН	Для коммерческой системы 3-го уровня не актуальны

В таблице 23 представлен адаптированный перечень угроз, актуальных для ИС «Бан-ID».

Таблица 23 — Адаптированный перечень угроз для ИС «Бан-ID»

№	Наименование
УБИ.003	Угроза использования слабостей криптографических алгоритмов и уязвимостей в программном обеспечении их реализации
УБИ.004	Угроза аппаратного сброса пароля BIOS
УБИ.006	Угроза внедрения кода или данных
УБИ.007	Угроза воздействия на программы с высокими привилегиями
УБИ.008	Угроза восстановления и/или повторного использования аутентификационной информации
УБИ.009	Угроза восстановления предыдущей уязвимой версии BIOS
УБИ.011	Угроза деавторизации санкционированного клиента беспроводной сети (при использовании Wi-Fi)
УБИ.012	Угроза деструктивного изменения конфигурации/среды окружения программ
УБИ.013	Угроза деструктивного использования декларированного функционала BIOS
УБИ.014	Угроза длительного удержания вычислительных ресурсов пользователями
УБИ.015	Угроза доступа к защищаемым файлам с использованием обходного пути
УБИ.016	Угроза доступа к локальным файлам сервера при помощи URL
УБИ.017	Угроза доступа/перехвата изменения HTTP cookies
УБИ.018	Угроза загрузки нештатной операционной системы
УБИ.019	Угроза заражения DNS-кеша
УБИ.022	Угроза избыточного выделения оперативной памяти
УБИ.023	Угроза изменения компонентов информационной (автоматизированной) системы
УБИ.025	Угроза изменения системных и глобальных переменных
УБИ.026	Угроза искажения XML-схемы

УБИ.028	Угроза использования альтернативных путей доступа к ресурсам
УБИ.030	Угроза использования информации идентификации/аутентификации, заданной по умолчанию
УБИ.031	Угроза использования механизмов авторизации для повышения привилегий
УБИ.032	Угроза использования поддельных цифровых подписей BIOS
УБИ.033	Угроза использования слабостей кодирования входных данных
УБИ.034	Угроза использования слабостей протоколов сетевого/локального обмена данными
УБИ.036	Угроза исследования механизмов работы программы
УБИ.037	Угроза исследования приложения через отчеты об ошибках
УБИ.039	Угроза исчерпания запаса ключей, необходимых для обновления BIOS
УБИ.041	Угроза межсайтового скриптинга
УБИ.042	Угроза межсайтовой подделки запроса
УБИ.051	Угроза невозможности восстановления сессии работы на ПЭВМ при выводе из промежуточных состояний питания
УБИ.053	Угроза невозможности управления правами пользователей BIOS
УБИ.059	Угроза неконтролируемого роста числа зарезервированных вычислительных ресурсов
УБИ.061	Угроза некорректного задания структуры данных транзакции
УБИ.062	Угроза некорректного использования прозрачного прокси-сервера за счет плагинов браузера
УБИ.063	Угроза некорректного использования функционала программного и аппаратного обеспечения
УБИ.067	Угроза неправомерного ознакомления с защищаемой информацией
УБИ.068	Угроза неправомерного/некорректного использования интерфейса взаимодействия с приложением

УБИ.069	Угроза неправомерных действий в каналах связи
УБИ.071	Угроза несанкционированного восстановления удаленной защищаемой информации
УБИ.072	Угроза несанкционированного выключения или обхода механизма защиты от записи в BIOS
УБИ.073	Угроза несанкционированного доступа к активному и (или) пассивному сетевому оборудованию
УБИ.074	Угроза несанкционированного доступа к аутентификационной информации
УБИ.083	Угроза несанкционированного доступа к системе по беспроводным каналам
УБИ.084	Угроза несанкционированного доступа к системе хранения данных
УБИ.086	Угроза несанкционированного изменения аутентификационной информации
УБИ.088	Угроза несанкционированного копирования защищаемой информации
УБИ.089	Угроза несанкционированного редактирования реестра
УБИ.090	Угроза несанкционированного создания учетной записи пользователя
УБИ.091	Угроза несанкционированного удаления защищаемой информации
УБИ.093	Угроза несанкционированного управления буфером
УБИ.095	Угроза несанкционированного управления указателями
УБИ.098	Угроза обнаружения открытых портов и идентификации привязанных к ним сетевых служб
УБИ.099	Угроза обнаружения хостов
УБИ.100	Угроза обхода некорректно настроенных механизмов аутентификации

УБИ.102	Угроза опосредованного управления группой программ через совместно используемые данные
УБИ.103	Угроза определения типов объектов защиты
УБИ.104	Угроза определения топологии вычислительной сети
УБИ.109	Угроза перебора всех настроек и параметров приложения
УБИ.111	Угроза передачи данных по скрытым каналам
УБИ.113	Угроза перезагрузки аппаратных и программно-аппаратных средств вычислительной техники
УБИ.114	Угроза переполнения целочисленных переменных
УБИ.115	Угроза перехвата вводимой и выводимой на периферийные устройства информации
УБИ.116	Угроза перехвата данных, передаваемых по вычислительной сети
УБИ.117	Угроза перехвата привилегированного потока
УБИ.118	Угроза перехвата привилегированного процесса
УБИ.121	Угроза повреждения системного реестра
УБИ.122	Угроза повышения привилегий
УБИ.123	Угроза подбора пароля BIOS
УБИ.124	Угроза подделки записей журнала регистрации событий
УБИ.125	Угроза подключения к беспроводной сети в обход процедуры аутентификации
УБИ.126	Угроза подмены беспроводного клиента или точки доступа
УБИ.127	Угроза подмены действия пользователя путем обмана
УБИ.128	Угроза подмены доверенного пользователя
УБИ.129	Угроза подмены резервной копии программного обеспечения BIOS
УБИ.130	Угроза подмены содержимого сетевых ресурсов
УБИ.131	Угроза подмены субъекта сетевого доступа
УБИ.132	Угроза получения предварительной информации об объекте защиты

УБИ.133	Угроза получения сведений о владельце беспроводного устройства
УБИ.139	Угроза преодоления физической защиты
УБИ.140	Угроза приведения системы в состояние «отказ в обслуживании»
УБИ.143	Угроза программного выведения из строя средств хранения, обработки и (или) ввода/вывода/передачи информации
УБИ.144	Угроза программного сброса пароля BIOS
УБИ.145	Угроза пропуска проверки целостности программного обеспечения
УБИ.149	Угроза сбоя обработки специальным образом измененных файлов
УБИ.150	Угроза сбоя процесса обновления BIOS
УБИ.151	Угроза сканирования веб-сервисов, разработанных на основе языка описания WSDL
УБИ.152	Угроза удаления аутентификационной информации
УБИ.153	Угроза усиления воздействия на вычислительные ресурсы пользователей при помощи сторонних серверов
УБИ.154	Угроза установки уязвимых версий обновления программного обеспечения BIOS
УБИ.155	Угроза утраты вычислительных ресурсов
УБИ.156	Угроза утраты носителей информации
УБИ.157	Угроза физического выведения из строя средств хранения, обработки и (или) ввода/вывода/передачи информации
УБИ.158	Угроза форматирования носителей информации
УБИ.159	Угроза «форсированного веб-браузинга»
УБИ.160	Угроза хищения средств хранения, обработки и (или) ввода/вывода/передачи информации
УБИ.162	Угроза эксплуатации цифровой подписи программного кода

УБИ.163	Угроза перехвата исключения/сигнала из привилегированного блока функций
УБИ.165	Угроза включения в проект не достоверно испытанных компонентов
УБИ.166	Угроза внедрения системной избыточности
УБИ.167	Угроза заражения компьютера при посещении неблагонадежных сайтов
УБИ.168	Угроза «кражи» учетной записи доступа к сетевым сервисам
УБИ.169	Угроза наличия механизмов разработчика
УБИ.170	Угроза неправомерного шифрования информации
УБИ.171	Угроза скрытого включения вычислительного устройства в состав бот-сети
УБИ.172	Угроза распространения «почтовых червей»
УБИ.173	Угроза «спама» веб-сервера
УБИ.174	Угроза «фарминга»
УБИ.175	Угроза «фишинга»
УБИ.177	Угроза неподтвержденного ввода данных оператором в систему, связанную с безопасностью
УБИ.178	Угроза несанкционированного использования системных и сетевых утилит
УБИ.179	Угроза несанкционированной модификации защищаемой информации
УБИ.180	Угроза отказа подсистемы обеспечения температурного режима
УБИ.182	Угроза физического устаревания аппаратных компонентов
УБИ.185	Угроза несанкционированного изменения параметров настройки средств защиты информации
УБИ.186	Угроза внедрения вредоносного кода через рекламу, сервисы и контент

УБИ.187	Угроза несанкционированного воздействия на средство защиты информации
УБИ.188	Угроза подмены программного обеспечения
УБИ.189	Угроза маскирования действий вредоносного кода
УБИ.190	Угроза внедрения вредоносного кода за счет посещения зараженных сайтов в сети Интернет
УБИ.191	Угроза внедрения вредоносного кода в дистрибутив программного обеспечения
УБИ.192	Угроза использования уязвимых версий программного обеспечения
УБИ.193	Угроза утечки информации за счет применения вредоносным программным обеспечением алгоритмов шифрования трафика
УБИ.197	Угроза хищения аутентификационной информации из временных файлов cookie
УБИ.198	Угроза скрытной регистрации вредоносной программой учетных записей администраторов
УБИ.201	Угроза утечки пользовательских данных при использовании функций автоматического заполнения аутентификационной информации в браузере
УБИ.205	Угроза нарушения работы компьютера и блокирования доступа к его данным из-за некорректной работы установленных на нем средств защиты
УБИ.208	Угроза нецелевого использования вычислительных ресурсов средства вычислительной техники
УБИ.209	Угроза несанкционированного доступа к защищаемой памяти ядра процессора
УБИ.211	Угроза использования непроверенных пользовательских данных при формировании конфигурационного файла
УБИ.212	Угроза перехвата управления информационной системой

УБИ.214	Угроза несвоевременного выявления и реагирования компонентами системы на события безопасности информации
УБИ.217	Угроза использования скомпрометированного доверенного источника обновлений программного обеспечения

Группировка адаптированного перечня угроз для дальнейшего определения сценариев реализации угроз безопасности информации представлена в таблице 24.

Таблица 24 — Группировка адаптированного перечня угроз

Группа угроз	№ угроз
Угрозы, связанные с уязвимостями в программном обеспечении	УБИ.003, УБИ.006, УБИ.007, УБИ.008, УБИ.009, УБИ.012, УБИ.013, УБИ.015, УБИ.016, УБИ.017, УБИ.018, УБИ.019, УБИ.022, УБИ.025, УБИ.028, УБИ.031, УБИ.032, УБИ.033, УБИ.034, УБИ.036, УБИ.037, УБИ.039, УБИ.041, УБИ.042, УБИ.053, УБИ.059, УБИ.061, УБИ.062, УБИ.063, УБИ.068, УБИ.071, УБИ.073, УБИ.074, УБИ.084, УБИ.086, УБИ.088, УБИ.089, УБИ.090, УБИ.091, УБИ.093, УБИ.095, УБИ.100, УБИ.102, УБИ.109, УБИ.111, УБИ.114, УБИ.117, УБИ.118, УБИ.121, УБИ.122, УБИ.124, УБИ.128, УБИ.130, УБИ.131, УБИ.144, УБИ.149, УБИ.150, УБИ.151, УБИ.152, УБИ.154, УБИ.155, УБИ.158, УБИ.159, УБИ.162, УБИ.163, УБИ.167, УБИ.168, УБИ.169, УБИ.170, УБИ.173, УБИ.174, УБИ.177, УБИ.178, УБИ.185, УБИ.187, УБИ.192, УБИ.201, УБИ.205, УБИ.211, УБИ.212, УБИ.214

Угрозы, связанные с уязвимостями в технических средствах	УБИ.004, УБИ.051, УБИ.067, УБИ.180, УБИ.182, УБИ.209
Угрозы, связанные с внедрением вредоносного кода	УБИ.006, УБИ.022, УБИ.041, УБИ.072, УБИ.115, УБИ.145, УБИ.167, УБИ.171, УБИ.172, УБИ.186, УБИ.188, УБИ.189, УБИ.190, УБИ.191, УБИ.193, УБИ.197, УБИ.198, УБИ.208, УБИ.217
Угрозы, связанные с технологиями беспроводного доступа	УБИ.011, УБИ.083, УБИ.125, УБИ.126, УБИ.133
Угрозы типа «отказ в обслуживании»	УБИ.014, УБИ.140, УБИ.143, УБИ.153
Угрозы, связанные с физическим воздействием на объект защиты	УБИ.023, УБИ.113, УБИ.129, УБИ.156, УБИ.157, УБИ.160, УБИ.179
Угрозы, связанные с несанкционированным доступом к сетевому трафику	УБИ.026, УБИ.061, УБИ.069, УБИ.075, УБИ.116
Угрозы, связанные со сбором информации об объекте защиты	УБИ.030, УБИ.036, УБИ.037, УБИ.098, УБИ.099, УБИ.103, УБИ.104, УБИ.132
Угрозы, связанные с социальной инженерией	УБИ.127, УБИ.139, УБИ.175
Угрозы, связанные с ошибками в	УБИ.165, УБИ.166

проектировании системы обеспечения информационной безопасности	
---	--

9.2 Описание возможных сценариев реализации угроз безопасности информации

Определение сценариев реализации угроз безопасности информации предусматривает установление последовательности возможных тактик и соответствующих им техник, применение которых возможно актуальным нарушителем с соответствующим уровнем возможностей, а также доступности интерфейсов для использования соответствующих способов реализации угроз безопасности информации.

При реализации угроз безопасности информации нарушителями могут быть задействованы тактики и техники в соответствии с таблицей 25.

Таблица 25 — Основные тактики и техники, используемые при построении сценариев

№	Тактика	Основные техники
T1	Сбор информации о системах и сетях	T1.1 (сбор из публичных источников), T1.2 (сбор информации о подключенных устройствах), T1.3 (пассивный сбор), T1.4 (направленное сканирование), T1.5 (сбор через эксплуатацию уязвимостей), T1.11 (социальная инженерия)

T2	Получение первоначального доступа к компонентам систем и сетей	T2.1 (использование внешних сервисов), T2.3 (эксплуатация уязвимостей сетевого оборудования), T2.4 (ошибки конфигурации), T2.5 (эксплуатация уязвимостей компонентов), T2.7 (использование внешних носителей), T2.8 (социальная инженерия), T2.10 (подбор учетных данных)
T3	Внедрение и исполнение вредоносного программного обеспечения	T3.1 (автоматический запуск), T3.3 (автоматическая загрузка с удаленного сайта), T3.4 (копирование через средства удаленного управления), T3.14 (запуск при старте ОС), T3.15 (запуск через планировщик задач)
T4	Закрепление (сохранение доступа) в системе или сети	T4.1 (несанкционированное создание учетных записей), T4.2 (использование штатных средств удаленного доступа), T4.3 (скрытая установка средств удаленного доступа), T4.5 (внесение записей в автозагрузку)
T5	Управление вредоносным программным обеспечением	T5.1 (удаленное управление через стандартные протоколы), T5.2 (использование штатных средств удаленного доступа), T5.3 (коммуникация через хорошо известные порты),

		T5.6 (проксирование трафика)
T6	Повышение привилегий по доступу к компонентам систем и сетей	T6.1 (получение данных для аутентификации), T6.2 (подбор пароля), T6.3 (эксплуатация уязвимостей ПО), T6.7 (использование уязвимостей конфигурации), T6.8 (эксплуатация уязвимостей контроля доступа)
T7	Соккрытие действий и применяемых при этом средств от обнаружения	T7.1 (использование штатных инструментов), T7.2 (очистка журналов), T7.3 (удаление файлов), T7.4 (отключение СЗИ), T7.12 (манипуляции именами процессов), T7.13 (создание скрытых файлов), T7.21 (Изменение конфигурации сети), T7.23 (подмена легитимных программ)
T8	Получение доступа (распространение доступа) к другим компонентам	T8.1 (эксплуатация уязвимостей), T8.2 (использование средств удаленного управления), T8.3 (использование механизмов дистанционной установки ПО), T8.4 (удаленное копирование файлов), T8.7 (размещение ВПО на разделяемых сетевых ресурсах)
T9	Сбор и вывод информации из системы	T9.1 (доступ через стандартные протоколы), T9.2 (штатные средства удаленного доступа),

		Т9.3 (вывод на хорошо известные порты), Т9.4 (вывод на нестандартные порты), Т9.5 (отправка данных по известным протоколам), Т9.10 (вывод через съемные носители)
Т10	Несанкционированный доступ и (или) воздействие на информационные ресурсы	Т10.1 (доступ к информации в памяти, ФС, БД), Т10.2 (воздействие на системное ПО), Т10.3 (воздействие на прикладное ПО), Т10.4 (воздействие на конфигурацию прикладного ПО), Т10.7 (подмена информации), Т10.8 (уничтожение информации), Т10.10 (организация отказа в обслуживании)

В таблице 26 приведены сценарии реализации угроз безопасности информации для различных видов нарушителей.

Таблица 26 — Сценарии реализации угроз безопасности информации

№	Вид нарушителя	Способы реализации	Техники/Тактики (по таблице 9.12)
1	Отдельные физические лица (хакеры) (Н1)	Использование уязвимостей; Внедрение вредоносного ПО; Ошибочные действия	T1.2, T1.3, T1.4, T1.5, T1.11; T2.1, T2.3, T2.4, T2.5, T2.8, T2.10, T2.13; T3.1, T3.3, T3.4, T3.14, T3.15; T4.1, T4.2, T4.3, T4.5; T5.1, T5.2, T5.3, T5.6; T6.1, T6.2, T6.3, T6.7, T6.8; T7.1, T7.2, T7.3, T7.4, T7.12, T7.13, T7.23; T8.1, T8.2, T8.3, T8.4, T8.7; T9.1, T9.2, T9.3, T9.4, T9.5, T9.10; T10.1, T10.2, T10.3, T10.4, T10.7, T10.8, T10.10
2	Преступные группы (криминальные структуры) (Н2)	Использование уязвимостей (в том числе недокументированных); Внедрение вредоносного ПО	T1.2, T1.3, T1.4, T1.5, T1.11, T1.16; T2.1, T2.3, T2.4, T2.5, T2.6, T2.8, T2.10, T2.13; T3.1, T3.3, T3.4, T3.7, T3.14, T3.15; T4.1, T4.2, T4.3, T4.5, T4.7; T5.1, T5.2, T5.3, T5.6, T5.11; T6.1, T6.2, T6.3, T6.4, T6.7, T6.8; T7.1, T7.2, T7.3, T7.4, T7.12, T7.13, T7.21, T7.23; T8.1, T8.2, T8.3, T8.4, T8.5, T8.7; T9.1, T9.2, T9.3, T9.4, T9.5, T9.6, T9.10; T10.1, T10.2, T10.3, T10.4, T10.5, T10.7, T10.8, T10.10
3	Разработчики программных, программно-	Использование уязвимостей; Внедрение вредоносного ПО (закладки);	T3.3; T8.7; T10.1, T10.2, T10.3, T10.4, T10.8, T10.10

	аппаратных средств (Н2)	Ошибочные действия	
4	Поставщики вычислительных услуг, услуг связи (персонал ЦОД) (Н2)	Нарушение безопасности при поставке услуг; Копирование информации; Внедрение ВПО; Установка закладок	T2.7, T2.12; T3.3; T4.7; T5.5; T9.10; T10.1, T10.2, T10.3, T10.4, T10.8
5	Лица, привлекаемые для установки, настройки, испытаний (Н2)	Использование уязвимостей; Внедрение ВПО (закладки); Ошибочные действия	T1.16; T2.7, T2.12; T3.3; T4.7; T5.5; T8.7; T9.10; T10.1, T10.2, T10.3, T10.4, T10.8, T10.10
6	Лица, обеспечивающие функционирование системы (охрана, уборщики, администрация) (Н1)	Ошибочные действия; Внедрение ВПО (через съёмные носители)	T2.7; T3.1, T3.3; T5.5; T7.3, T7.13; T9.10; T10.1, T10.2, T10.3, T10.8

7	Авторизованные пользователи (Служба безопасности, Секретариат) (Н1)	Использование уязвимостей; Ошибочные действия; Внедрение ВПО	T2.5, T2.10; T3.1, T3.3, T3.14, T3.15; T4.1, T4.2, T4.3, T4.5; T5.1, T5.2, T5.3; T6.1, T6.2, T6.3; T7.1, T7.2, T7.4, T7.13; T8.1, T8.4; T9.1, T9.2, T9.3, T9.5; T10.1, T10.2, T10.3, T10.4, T10.7, T10.8, T10.10
8	Системные администраторы и администраторы безопасности (Н2)	Использование уязвимостей; Внедрение ВПО; Ошибочные действия	T3.3; T4.2, T4.3, T4.5; T5.1, T5.2; T7.1, T7.2, T7.4, T7.21; T8.7; T9.1, T9.2; T10.1, T10.2, T10.3, T10.4, T10.5, T10.7, T10.8, T10.10
9	Бывшие работники (Н1)	Использование уязвимостей; Внедрение ВПО	T2.5, T2.10; T3.3, T3.14, T3.15; T4.1, T4.2, T4.3, T4.5; T5.1, T5.2; T6.1, T6.2, T6.3; T7.1, T7.2, T7.4; T8.1, T8.4; T9.1, T9.2, T9.3, T9.5; T10.1, T10.2, T10.3, T10.4, T10.7, T10.8, T10.10

9.3 Выводы об актуальности угроз безопасности информации

Для определения актуальности угроз безопасности информации рассматривается перечень возможных угроз безопасности информации (таблица 24) и анализируется наличие сценариев их реализации (таблица 26). Наличие хотя бы одного сценария реализации угрозы безопасности информации является основанием для признания такой угрозы актуальной для ИС «Бан-ID».

Актуальные угрозы безопасности информации для ИС «Бан-ID» приведены в таблице 27.

Таблица 27 — Актуальные угрозы безопасности информации для ИС «Бан-ID»

Идентификатор и наименование УБИ	Описание угрозы	Нарушаемая характеристика	Источники угрозы	Объект воздействия	Сценарий	Актуальность угрозы
УБИ.003: Угроза использования слабостей криптографических алгоритмов и уязвимостей в программном обеспечении их реализации	Возможность дешифрования трафика или подбора ключей шифрования	Конфиденциальность, Целостность	Хакеры (Н1), Преступные группы (Н2)	Системное ПО, Каналы связи	T1.2, T1.4, T1.5	Актуальна
УБИ.004: Угроза аппаратного сброса пароля BIOS	Физический сброс пароля BIOS для получения доступа к оборудованию	Конфиденциальность, Доступность	Лица, обеспечивающие функционирование (Н1)	Технические средства (BIOS)	T7.21, T10.1	Актуальна

УБИ.006: Угроза внедрения кода или данных	Загрузка и выполнение вредоносного ПО в системе	Конфиденциальность, Целостность	Хакеры (Н1), Преступные группы (Н2), Разработчики (Н2)	Программные средства, АРМ	Т3.1, Т3.3, Т3.4, Т3.14, Т3.15	Актуальна
УБИ.007: Угроза воздействия на программы с высокими привилегиями	Запуск вредоносного кода с правами администратора или системы	Конфиденциальность, Целостность, Доступность	Системные администраторы (Н2), Преступные группы (Н2)	Системное ПО, Ядро ОС	Т6.3, Т6.7	Актуальна
УБИ.008: Угроза восстановления и/или повторного использования аутентификационной информации	Перехват или подбор хэшей паролей, использование украденных сессий	Конфиденциальность	Хакеры (Н1), Бывшие работники (Н1)	АРМ, Системное ПО	Т2.10, Т2.13, Т6.1, Т6.2	Актуальна

УБИ.009: Угроза восстановления предыдущей уязвимой версии BIOS	Откат версии BIOS к версии с известными неустранёнными уязвимостями	Целостность	Лица, обеспечивающие функционирование (Н1)	Технические средства (BIOS)	T7.21	Актуальна
УБИ.011: Угроза деавторизации санкционированного клиента беспроводной сети	Принудительный разрыв соединения пользователя Wi-Fi для перехвата данных	Конфиденциальность, Доступность	Хакеры (Н1), Преступные группы (Н2)	Телекоммуникационное оборудование (Wi-Fi)	T2.3, T2.13	Актуальна
УБИ.012: Угроза деструктивного изменения конфигурации/среды окружения программ	Изменение системных переменных, файлов hosts, реестра для перенаправления трафика	Конфиденциальность, Доступность	Системные администраторы (Н2), Авторизованные пользователи (Н1)	Программные средства, АРМ	T4.5, T10.2	Актуальна

УБИ.013: Угроза деструктивного использования декларируемого функционала BIOS	Использование штатных функций BIOS (например, удаление данных) против системы	Доступность, Целостность	Лица, обеспечивающие функционирование (Н1)	Технические средства (BIOS)	T10.8	Актуальна
УБИ.014: Угроза длительного удержания вычислительных ресурсов пользователями	Запуск «майнеров» или ресурсоемких процессов, вызывающих отказ оборудования	Доступность	Хакеры (Н1), Авторизованные пользователи (Н1)	АРМ, Сервер приложений	T3.3, T10.10	Актуальна
УБИ.015: Угроза доступа к защищаемым файлам с использованием обходного пути	Навигация по файловой системе сервера через уязвимости типа Path Traversal	Конфиденциальность	Хакеры (Н1)	Сервер БД, Сервер приложений	T1.5	Актуальна

УБИ.016: Угроза доступа к локальным файлам сервера при помощи URL	Запрос служебных файлов системы через веб-интерфейс (например, .git/config)	Конфиденциальность	Хакеры (Н1)	Веб-приложение	T1.5, T2.5	Актуальна
УБИ.017: Угроза доступа/перехвата изменения HTTP cookies	Кража сессионных cookie для входа в систему без пароля	Конфиденциальность	Хакеры (Н1), Бывшие работники (Н1)	Веб-приложение, Сетевой трафик	T2.13, T6.1	Актуальна
УБИ.018: Угроза загрузки нештатной операционной системы	Загрузка ОС с Live-USB в обход установленной защищенной ОС	Конфиденциальность	Лица, обеспечивающие функционирование (Н1)	Технические средства (АРМ)	T7.21, T10.1	Актуальна
УБИ.019: Угроза заражения DNS-кеша	Перенаправление пользователей на поддельные сайты (фишинг) через отравление DNS	Конфиденциальность, Доступность	Преступные группы (Н2)	Телекоммуникационное оборудование	T2.13	Актуальна

УБИ.022: Угроза избыточного выделения оперативной памяти	«Пожирание» памяти для вызова отказа в обслуживании (DoS)	Доступность	Хакеры (Н1), Авторизованные пользователи (Н1)	Сервер приложений	T10.10	Актуальна
УБИ.023: Угроза изменения компонентов информационной (автоматизированной) системы	Физическая замена или модификация аппаратных компонентов (ОЗУ, диски)	Целостность, Конфиденциальность	Лица, обеспечивающие функционирование (Н1)	АРМ, Серверы	T10.8, T10.7	Актуальна
УБИ.025: Угроза изменения системных и глобальных переменных	Модификация переменных окружения для запуска вредоносного ПО	Конфиденциальность, Целостность	Системные администраторы (Н2)	Системное ПО	T4.3, T10.2	Актуальна
УБИ.026: Угроза искажения XML-схемы	Внедрение внешних сущностей (XXE) для чтения файлов сервера	Конфиденциальность	Хакеры (Н1)	Веб-приложение	T1.5	Актуальна
УБИ.028: Угроза использования	Обход контроля доступа через	Конфиденциальность	Авторизованные	Веб-приложение,	T2.5	Актуальна

альтернативных путей доступа к ресурсам	прямые ссылки на файлы		пользователи (Н1), Хакеры (Н1)	Сервер приложений		
УБИ.030: Угроза использования информации идентификации/аутентификации, заданной по умолчанию	Вход в систему с логином/паролем admin/admin или guest/guest	Конфиденциальность	Хакеры (Н1), Бывшие работники (Н1)	Системное ПО, Сетевое оборудование	T2.4, T2.10	Актуальна
УБИ.031: Угроза использования механизмов авторизации для повышения привилегий	Использование уязвимостей для получения прав администратора	Конфиденциальность, Целостность	Авторизованные пользователи (Н1), Хакеры (Н1)	Системное ПО, СУБД	T6.3, T6.7	Актуальна
УБИ.032: Угроза использования поддельных цифровых подписей BIOS	Прошивка модифицированного BIOS, подписанного украденными ключами	Целостность	Преступные группы (Н2)	Технические средства	T3.11, T7.27	Актуальна

УБИ.033: Угроза использования слабостей кодирования входных данных	SQL-инъекции, командные инъекции, XSS-атаки	Конфиденциальность, Целостность	Хакеры (Н1)	Веб-приложение, СУБД	T2.5	Актуальна
УБИ.034: Угроза использования слабостей протоколов сетевого/локального обмена данными	Атаки типа ARP-spoofing или sniffing трафика	Конфиденциальность	Хакеры (Н1), Преступные группы (Н2)	Телекоммуникационное оборудование	T2.13	Актуальна
УБИ.036: Угроза исследования механизмов работы программы	Обратная разработка (Reverse Engineering) мобильного или десктопного приложения	Конфиденциальность	Преступные группы (Н2)	Прикладное ПО	T1.9	Актуальна
УБИ.037: Угроза исследования приложения через отчеты об ошибках	Анализ детализированных сообщений об ошибках для	Конфиденциальность	Хакеры (Н1)	Веб-приложение	T1.1, T1.5	Актуальна

	выявления структуры БД					
УБИ.039: Угроза истощения запаса ключей, необходимых для обновления BIOS	Невозможность установки безопасных обновлений BIOS из-за отсутствия ключей	Доступность	Системные администраторы (H2)	Технические средства	T7.21	Актуальна
УБИ.041: Угроза межсайтового скриптинга	Внедрение JavaScript-кода в веб-страницы для кражи сессий	Конфиденциальность	Хакеры (H1)	Веб-приложение	T2.5	Актуальна
УБИ.042: Угроза межсайтовой подделки запроса	Выполнение действий от имени администратора через подставную ссылку	Целостность	Хакеры (H1)	Веб-приложение	T2.5	Актуальна
УБИ.051: Угроза невозможности восстановления сессии работы на ПЭВМ при выводе	Потеря несохраненных данных при сбоях электропитания	Доступность	Техногенные источники	АРМ	T7.21	Актуальна

из промежуточных состояний питания						
УБИ.053: Угроза невозможности управления правами пользователей BIOS	Отсутствие контроля над загрузкой оборудования после взлома BIOS	Конфиденциальность	Лица, обеспечивающие функционирование (Н1)	Технические средства	T7.21	Актуальна
УБИ.059: Угроза неконтролируемого роста числа зарезервированных выбранных ресурсов	Потребление всех системных ресурсов «паразитными» процессами	Доступность	Хакеры (Н1), Авторизованные пользователи (Н1)	Сервер приложений	T10.10	Актуальна
УБИ.061: Угроза некорректного задания структуры данных транзакции	Ошибки в сериализации данных, ведущие к сбоям в работе API	Доступность, Целостность	Разработчики (Н2)	Веб-приложение	T1.5	Актуальна
УБИ.062: Угроза некорректного использования прозрачного	Установка вредоносных расширений	Конфиденциальность	Авторизованные пользователи (Н1)	АРМ	T3.3	Актуальна

прокси-сервера за счет плагинов браузера	браузера для перехвата данных					
УБИ.063: Угроза некорректного использования функционала программного и аппаратного обеспечения	Использование отладочных портов и утилит для обхода защиты	Конфиденциальность	Системные администраторы (H2)	Технические средства	T10.7	Актуальна
УБИ.067: Угроза неправомерного ознакомления с защищаемой информацией	Визуальный просмотр данных на экране монитора посторонними	Конфиденциальность	Лица, обеспечивающие функционирование (H1)	АРМ	T1.13	Актуальна
УБИ.068: Угроза неправомерного/некорректного использования интерфейса взаимодействия с приложением	Подбор ID записей в URL для просмотра чужих данных	Конфиденциальность	Авторизованные пользователи (H1)	Веб-приложение	T2.5	Актуальна

УБИ.069: Угроза неправомерных действий в каналах связи	Подключение к кабельным линиям связи для прослушки трафика	Конфиденциальность	Преступные группы (Н2)	Телекоммуникационное оборудование	T2.13	Актуальна
УБИ.071: Угроза несанкционированного восстановления удаленной защищаемой информации	Восстановление удаленных файлов с диска с помощью спец. утилит	Конфиденциальность	Системные администраторы (Н2)	Машинные носители	T10.1	Актуальна
УБИ.072: Угроза несанкционированного выключения или обхода механизма защиты от записи в BIOS	Снятие защиты с BIOS для прошивки вредоносного кода	Целостность	Лица, обеспечивающие функционирование (Н1)	Технические средства	T7.21	Актуальна
УБИ.073: Угроза несанкционированного доступа к активному и (или) пассивному	Вход в настройки коммутатора/маршрутизатора через веб-интерфейс	Конфиденциальность	Системные администраторы (Н2)	Телекоммуникационное оборудование	T2.4	Актуальна

сетевому оборудованию						
УБИ.074: Угроза несанкционированного доступа к аутентификационной информации	Чтение файлов конфигурации с паролями или дампов памяти	Конфиденциальность	Системные администраторы (Н2)	Системное ПО	T6.1	Актуальна
УБИ.083: Угроза несанкционированного доступа к системе по беспроводным каналам	Подключение к корпоративному Wi-Fi через подбор пароля	Конфиденциальность	Хакеры (Н1)	Телекоммуникационное оборудование	T2.4, T2.10	Актуальна
УБИ.084: Угроза несанкционированного доступа к системе хранения данных	Прямое подключение к СХД или виртуальным дискам сервера	Конфиденциальность	Поставщики услуг (Н2), Системные администраторы (Н2)	Машинные носители, Сервер БД	T10.1	Актуальна
УБИ.086: Угроза несанкционированного изменения аутентификационной информации	Смена пароля администратора системы	Доступность	Системные администраторы (Н2)	Системное ПО	T4.1, T10.2	Актуальна

УБИ.088: Угроза несанкционированного копирования защищаемой информации	Копирование базы данных на USB-накопитель или в облако	Конфиденциальность	Системные администраторы (Н2), Авторизованные пользователи (Н1)	Машинные носители	T9.10	Актуальна
УБИ.089: Угроза несанкционированного редактирования реестра	Изменение ключей автозагрузки в ОС	Целостность	Системные администраторы (Н2)	Системное ПО	T3.14	Актуальна
УБИ.090: Угроза несанкционированного создания учетной записи пользователя	Создание скрытого пользователя для удаленного доступа	Конфиденциальность	Системные администраторы (Н2)	Системное ПО	T4.1	Актуальна
УБИ.091: Угроза несанкционированного удаления защищаемой информации	Удаление таблиц базы данных (DROP), удаление логов аудита	Доступность	Системные администраторы (Н2)	СУБД, Системное ПО	T10.8	Актуальна

УБИ.093: Угроза несанкционированного управления буфером	Переполнение буфера для выполнения произвольного кода	Целостность	Хакеры (Н1)	Системное ПО	T2.5	Актуальна
УБИ.095: Угроза несанкционированного управления указателями	Использование "диких" указателей для выполнения кода	Целостность	Хакеры (Н1)	Прикладное ПО	T2.5	Актуальна
УБИ.098: Угроза обнаружения открытых портов и идентификации привязанных к ним сетевых служб	Сканирование портов (nmap) для поиска векторов атаки	Конфиденциальность	Хакеры (Н1)	Телекоммуникационное оборудование	T1.2, T1.4	Актуальна
УБИ.099: Угроза обнаружения хостов	Определение IP-адресов серверов и АРМ в сети	Конфиденциальность	Хакеры (Н1)	Телекоммуникационное оборудование	T1.2, T1.4	Актуальна
УБИ.100: Угроза обхода некорректно настроенных	Вход в систему через подстановку заголовков или	Конфиденциальность	Хакеры (Н1)	Веб-приложение	T2.5	Актуальна

механизмов аутентификации	обход страницы входа					
УБИ.102: Угроза опосредованного управления группой программ через совместно используемые данные	Заражение DLL-библиотек, используемых разными программами	Целостность	Хакеры (Н1)	Прикладное ПО	T3.7	Актуальна
УБИ.103: Угроза определения типов объектов защиты	Выявление операционной системы (fingerprinting) серверов	Конфиденциальность	Хакеры (Н1)	Телекоммуникационное оборудование	T1.4, T1.5	Актуальна
УБИ.104: Угроза определения топологии вычислительной сети	Построение карты сети (traceroute) для анализа маршрутов	Конфиденциальность	Хакеры (Н1)	Телекоммуникационное оборудование	T1.4	Актуальна
УБИ.109: Угроза перебора всех настроек и	Fuzzing-атаки на API для поиска скрытых методов или ошибок	Конфиденциальность	Хакеры (Н1)	Веб-приложение	T1.5	Актуальна

параметров приложения						
УБИ.111: Угроза передачи данных по скрытым каналам	Туннелирование трафика управления внутри DNS-запросов	Конфиденциальность	Преступные группы (Н2)	Телекоммуникационное оборудование	T5.8, T7.20	Актуальна
УБИ.113: Угроза перезагрузки аппаратных и программно-аппаратных средств вычислительной техники	Принудительная перезагрузка системы (Reboot)	Доступность	Лица, обеспечивающие функционирование (Н1)	АРМ, Серверы	T7.21	Актуальна
УБИ.114: Угроза переполнения целочисленных переменных	Атаки на целочисленное переполнение в математических операциях	Доступность	Хакеры (Н1)	Прикладное ПО	T2.5	Актуальна
УБИ.115: Угроза перехвата вводимой и	Кейлоггеры (перехват нажатий клавиш)	Конфиденциальность	Системные администраторы (Н2)	АРМ	T3.3	Актуальна

выводимой на периферийные устройства информации						
УБИ.116: Угроза перехвата данных, передаваемых по вычислительной сети	Сниффинг трафика (перехват пакетов) в ЛВС	Конфиденциальность	Хакеры (Н1)	Телекоммуникационное оборудование	T2.13	Актуальна
УБИ.117: Угроза перехвата привилегированного потока	Перехват токенов авторизации администраторов	Конфиденциальность	Хакеры (Н1)	Системное ПО	T6.1	Актуальна
УБИ.118: Угроза перехвата привилегированного процесса	Внедрение в процесс, работающий от имени системы	Конфиденциальность	Хакеры (Н1)	Системное ПО	T6.3	Актуальна
УБИ.121: Угроза повреждения системного реестра	Редактирование реестра, приводящее к отказу загрузки ОС	Доступность	Системные администраторы (Н2)	Системное ПО	T10.2	Актуальна

УБИ.122: Угроза повышения привилегий (EoP)	Получение root/административных прав через эксплойты	Конфиденциальность, Целостность	Авторизованные пользователи (H1)	Системное ПО	T6.3	Актуальна
УБИ.123: Угроза подбора пароля BIOS	Перебор пароля BIOS для получения доступа к настройкам железа	Конфиденциальность	Лица, обеспечивающие функционирование (H1)	Технические средства	T2.10	Актуальна
УБИ.124: Угроза подделки записей журнала регистрации событий	Очистка или отключение логов безопасности (Audit log)	Конфиденциальность	Системные администраторы (H2)	Системное ПО	T7.2	Актуальна
УБИ.125: Угроза подключения к беспроводной сети в обход процедуры аутентификации	Атаки типа Evil Twin на Wi-Fi сети	Конфиденциальность	Хакеры (H1)	Телекоммуникационное оборудование	T2.13	Актуальна
УБИ.126: Угроза подмены беспроводного	MAC-спуфинг для маскировки	Конфиденциальность	Хакеры (H1)	Телекоммуникационное	T2.13	Актуальна

клиента или точки доступа	под легальное устройство			оборудовани е		
УБИ.127: Угроза подмены действия пользователя путем обмана	Социальная инженерия (звонок от "инженера")	Конфиденциальность	Хакеры (Н1)	Пользовател и системы	T1.11, T2.8	Актуальна
УБИ.128: Угроза подмены доверенного пользователя	Использование украденных сессионных данных сотрудника	Конфиденциальность	Хакеры (Н1), Бывшие работники (Н1)	Веб- приложение	T2.13, T6.1	Актуальна
УБИ.129: Угроза подмены резервной копии программного обеспечения BIOS	Прошивка бэкапа BIOS, содержащего закладки	Целостность	Лица, обеспечиваю щие функциониров ание (Н1)	Технические средства	T7.23	Актуальна
УБИ.130: Угроза подмены содержимого сетевых ресурсов	Подмена страницы обновления ПО на фишинговую	Конфиденциальность	Преступные группы (Н2)	Телекоммун икационное оборудовани е	T3.8, T3.9	Актуальна
УБИ.131: Угроза подмены субъекта сетевого доступа	IP-спуфинг для обхода правил	Конфиденциальность	Хакеры (Н1)	Телекоммун икационное	T2.13	Актуальна

	межсетевого экрана			оборудовани е		
УБИ.132: Угроза получения предварительной информации об объекте защиты	Сбор информации через поисковики (Google Dorks)	Конфиденциальность	Хакеры (Н1)	Веб-приложение	T1.1, T1.2	Актуальна
УБИ.133: Угроза получения сведений о владельце беспроводного устройства	Сбор MAC-адресов и определение производителя устройств	Конфиденциальность	Хакеры (Н1)	Телекоммуни кационное оборудовани е	T1.3	Актуальна
УБИ.139: Угроза преодоления физической защиты	Проникновение в серверную или офис для хищения носителей	Конфиденциальность	Преступные группы (Н2)	Помещения, Машинные носители	T7.21	Актуальна
УБИ.140: Угроза приведения системы в состояние «отказ в обслуживании»	DoS/DDoS-атаки на веб-сервер	Доступность	Преступные группы (Н2), Хакеры (Н1)	Веб-приложение	T10.10	Актуальна

УБИ.143: Угроза программного вывода из строя средств хранения, обработки и (или) ввода/вывода/передачи информации	Использование эксплойтов для "убийства" железа (кирпич)	Доступность	Хакеры (Н1)	Технические средства	T3.3	Актуальна
УБИ.144: Угроза программного сброса пароля BIOS	Сброс BIOS через утилиты из-под ОС	Конфиденциальность	Системные администраторы (Н2)	Технические средства	T10.2	Актуальна
УБИ.145: Угроза пропуска проверки целостности программного обеспечения	Обход механизмов контроля (HIPS, whitelisting)	Целостность	Системные администраторы (Н2)	Системное ПО	T7.4	Актуальна
УБИ.149: Угроза сбоя обработки специальным образом измененных файлов	"Бомбинг" архивами (Zip bomb) для переполнения диска	Доступность	Хакеры (Н1)	Сервер приложений	T10.10	Актуальна

УБИ.150: Угроза сбоя процесса обновления BIOS	Прерывание питания или использование кривого файла прошивки	Доступность	Лица, обеспечивающие функционирование (Н1)	Технические средства	T7.21	Актуальна
УБИ.151: Угроза сканирования веб-сервисов, разработанных на основе языка описания WSDL	Анализ WSDL-файлов для поиска скрытых методов API	Конфиденциальность	Хакеры (Н1)	Веб-приложение	T1.4, T1.5	Актуальна
УБИ.152: Угроза удаления аутентификационной информации	Сброс пароля пользователя администратором	Доступность	Системные администраторы (Н2)	Системное ПО	T10.5	Актуальна
УБИ.153: Угроза усиления воздействия на вычислительные ресурсы пользователей при помощи сторонних серверов	Атаки типа DNS Amplification или DDoS через NTP	Доступность	Преступные группы (Н2)	Телекоммуникационное оборудование	T10.10	Актуальна

УБИ.154: Угроза установки уязвимых версий обновления программного обеспечения BIOS	Откат драйверов или прошивок до версий с уязвимостями	Целостность	Лица, обеспечивающие функционирование (Н1)	Технические средства	T7.23, T7.24	Актуальна
УБИ.155: Угроза утраты вычислительных ресурсов	Захват сервера в бот-сеть для DDoS-атак	Доступность	Преступные группы (Н2)	Сервер приложений	T3.3, T10.11	Актуальна
УБИ.156: Угроза утраты носителей информации	Потеря или кража ноутбука, флешки или жесткого диска	Конфиденциальность	Лица, обеспечивающие функционирование (Н1)	Машинные носители	T7.13, T9.10	Актуальна
УБИ.157: Угроза физического вывода из строя средств хранения, обработки и (или) ввода/вывода/передачи информации	Физическое повреждение сервера (пожар, залив, разбитие)	Доступность	Лица, обеспечивающие функционирование (Н1)	Технические средства	T7.21	Актуальна

УБИ.158: Угроза форматирования носителей информации	Полное удаление всех данных с диска (форматирование)	Доступность	Системные администраторы (Н2)	Машинные носители	T10.8	Актуальна
УБИ.159: Угроза «форсированного веб-браузинга»	Прямой перебор ID сущностей (например, /user?id=1,2,3...)	Конфиденциальность	Хакеры (Н1)	Веб-приложение	T2.5	Актуальна
УБИ.160: Угроза хищения средств хранения, обработки и (или) ввода/вывода/передачи информации	Кража серверного оборудования (SSD, ОЗУ) из ЦОД	Конфиденциальность, Доступность	Преступные группы (Н2)	Технические средства, ЦОД	T7.21	Актуальна
УБИ.162: Угроза эксплуатации цифровой подписи программного кода	Использование украденных сертификатов для подписи вирусов	Целостность	Преступные группы (Н2)	Системное ПО	T3.11	Актуальна
УБИ.163: Угроза перехвата исключения/сигнала из	Перехват системных вызовов для скрытия	Конфиденциальность	Системные администраторы (Н2)	Системное ПО	T6.3	Актуальна

привилегированно го блока функций	вредоносной активности					
УБИ.165: Угроза включения в проект не достоверно испытанных компонентов	Внедрение "троянизированн ых" open-source библиотек	Конфиденциальность	Разработчики (Н2)	Прикладное ПО	T3.12	Актуальна
УБИ.166: Угроза внедрения системной избыточности	Установка "золотого" билета (Golden Ticket) в Active Directory	Конфиденциальность	Системные администрато ры (Н2)	Системное ПО	T4.1	Актуальна
УБИ.167: Угроза заражения компьютера при посещении неблагонадежных сайтов	Drive-by download при посещении сотрудником "левого" сайта	Конфиденциальность	Хакеры (Н1)	АРМ	T3.3	Актуальна
УБИ.168: Угроза «кражи» учетной записи доступа к сетевым сервисам	Кейлоггеры или перехват логинов через поддельные формы	Конфиденциальность	Хакеры (Н1)	АРМ, Веб- приложение	T1.11, T3.3	Актуальна

УБИ.169: Угроза наличия механизмов разработчика	Использование "бэкдоров", оставленных программистами	Конфиденциальность	Разработчики (Н2)	Прикладное ПО	T2.6	Актуальна
УБИ.170: Угроза неправомерного шифрования информации	Атака вируса-шифровальщика (Ransomware)	Доступность	Преступные группы (Н2)	Машинные носители	T3.3	Актуальна
УБИ.171: Угроза скрытого включения вычислительного устройства в состав бот-сети	Участие сервера в DDoS-атаках на третьих лиц	Доступность	Преступные группы (Н2)	Сервер приложений	T3.3, T10.11	Актуальна
УБИ.172: Угроза распространения «почтовых червей»	Рассылка фишинговых писем с зараженными файлами с адреса компании	Конфиденциальность	Хакеры (Н1)	АРМ, Системное ПО	T3.3	Актуальна
УБИ.173: Угроза «спама» веб-сервера	Комментарии со спам-ссылками	Доступность	Хакеры (Н1)	Веб-приложение	T1.5	Актуальна

	на страницах сайта					
УБИ.174: Угроза «фарминга»	Подмена DNS-записей для перенаправления на поддельный сайт	Конфиденциальность	Преступные группы (Н2)	Телекоммуникационное оборудование	T2.13	Актуальна
УБИ.175: Угроза «фишинга»	Массовая рассылка писем от лица лиги для сбора паролей	Конфиденциальность	Хакеры (Н1), Преступные группы (Н2)	Пользователи и системы	T1.11, T2.8	Актуальна
УБИ.177: Угроза неподтвержденного ввода данных оператором в систему, связанную с безопасностью	Человеческий фактор: внесение ложной информации о бане (ошибочно)	Целостность	Авторизованные пользователи (Н1)	АРМ, Прикладное ПО	T10.7	Актуальна
УБИ.178: Угроза несанкционированного использования	Использование PsExec, PowerShell для удаленного выполнения кода	Конфиденциальность	Системные администраторы (Н2)	Системное ПО	T5.1	Актуальна

системных и сетевых утилит						
УБИ.179: Угроза несанкционированной модификации защищаемой информации	Прямое редактирование записей в БД через SQL-клиент	Целостность	Системные администраторы (Н2)	СУБД	T10.1	Актуальна
УБИ.180: Угроза отказа подсистемы обеспечения температурного режима	Перегрев оборудования из-за поломок кондиционеров в серверной	Доступность	Техногенные источники	Серверы, ЦОД	T7.21	Актуальна
УБИ.182: Угроза физического устаревания аппаратных компонентов	Выход из строя HDD/SSD из-за износа	Доступность	Техногенные источники	Технические средства	T7.21	Актуальна
УБИ.185: Угроза несанкционированного изменения параметров настройки средств	Отключение антивирусной защиты или межсетевого экрана администратором	Конфиденциальность	Системные администраторы (Н2)	Системное ПО (СЗИ)	T7.4	Актуальна

защиты информации						
УБИ.186: Угроза внедрения вредоносного кода через рекламу, сервисы и контент	Заражение через рекламные баннеры на сторонних сайтах	Конфиденциальность	Хакеры (Н1)	АРМ	Т3.3	Актуальна
УБИ.187: Угроза несанкционированного воздействия на средство защиты информации	Подмена антивирусных баз данных	Конфиденциальность	Системные администраторы (Н2)	Системное ПО (СЗИ)	Т3.7, Т7.23	Актуальна
УБИ.188: Угроза подмены программного обеспечения	Замена легитимного ПО на вредоносное (тройнизация)	Конфиденциальность	Разработчики (Н2), Системные администраторы (Н2)	Прикладное ПО	Т3.7	Актуальна
УБИ.189: Угроза маскирования действий вредоносного кода	Руткиты, скрывающие процессы и файлы вирусов в системе	Конфиденциальность	Хакеры (Н1)	Системное ПО	Т7.10, Т7.18	Актуальна

УБИ.190: Угроза внедрения вредоносного кода за счет посещения зараженных сайтов в сети Интернет	Загрузка вирусов через зараженные сайты (Watering hole)	Конфиденциальность	Хакеры (Н1)	АРМ	T3.3	Актуальна
УБИ.191: Угроза внедрения вредоносного кода в дистрибутив программного обеспечения	Загрузка зараженной версии приложения с "левого" сайта	Конфиденциальность	Авторизованные пользователи (Н1)	АРМ	T3.3	Актуальна
УБИ.192: Угроза использования уязвимых версий программного обеспечения	Несвоевременная установка патчей безопасности	Конфиденциальность	Системные администраторы (Н2)	Системное и прикладное ПО	T1.5	Актуальна
УБИ.193: Угроза утечки информации за счет применения вредоносным программным	Соккрытие вредоносной активности под видом HTTPS-трафика	Конфиденциальность	Хакеры (Н1)	Телекоммуникационное оборудование	T5.10, T7.17	Актуальна

обеспечением алгоритмов шифрования трафика						
УБИ.197: Угроза хищения аутентификационной информации из временных файлов cookie	Извлечение сессионных данных из файлов на диске	Конфиденциальность	Хакеры (Н1)	АРМ	Т1.9	Актуальна
УБИ.198: Угроза скрытой регистрации вредоносной программой учетных записей администраторов	Создание скрытого пользователя в системе для удаленного доступа	Конфиденциальность	Системные администраторы (Н2)	Системное ПО	Т4.1	Актуальна
УБИ.201: Угроза утечки пользовательских данных при использовании функций	Извлечение сохраненных в браузере паролей	Конфиденциальность	Хакеры (Н1)	АРМ	Т1.9, Т3.3	Актуальна

автоматического заполнения аутентификационн ой информации в браузере						
УБИ.205: Угроза нарушения работы компьютера и блокирования доступа к его данным из-за некорректной работы установленных на нем средств защиты	Конфликт антивируса с системой, вызывающий синий экран смерти	Доступность	Системные администрато ры (H2)	Системное ПО	T7.4	Актуальна
УБИ.208: Угроза нецелевого использования вычислительных ресурсов средства вычислительной техники	Майнинг криптовалют на серверах компании	Доступность	Авторизованн ые пользователи (H1)	Сервер приложений	T3.3	Актуальна

УБИ.209: Угроза несанкционированного доступа к защищаемой памяти ядра процессора	Атаки типа Rowhammer для изменения данных в памяти	Конфиденциальность	Хакеры (Н1)	Технические средства	T10.1	Актуальна
УБИ.211: Угроза использования непроверенных пользовательских данных при формировании конфигурационного файла	Использование устаревших конфигураций, ведущее к ошибкам	Целостность	Системные администраторы (Н2)	Системное ПО	T7.21	Актуальна
УБИ.212: Угроза перехвата управления информационной системой	Полный захват контроля над сервером (Root/Admin)	Конфиденциальность	Системные администраторы (Н2)	Системное ПО	T6.3	Актуальна
УБИ.214: Угроза несвоевременного выявления и реагирования	Позднее обнаружение атаки из-за того, что алерты	Доступность	Системные администраторы (Н2)	Системное ПО (SIEM)	T7.4	Актуальна

компонентами системы на события безопасности информации	приходят с задержкой					
УБИ.217: Угроза использования скомпрометирован ного доверенного источника обновлений программного обеспечения	Отравление репозитория Linux	Конфиденциальность	Преступные группы (Н2)	Системное ПО	Т3.8, Т3.9	Актуальна

10 Применение средств криптографической защиты информации

10.1 Определение актуальности использования СКЗИ для обеспечения безопасности персональных данных

В информационной системе «Бан-ID» осуществляется передача персональных данных болельщиков (ФИО, паспортные данные, номер телефона) между территориально удалёнными сегментами (офис Оператора — стадионы) по каналам связи, не защищённым от перехвата нарушителем передаваемой по ним информации (сеть «Интернет»), а также от несанкционированных воздействий на эту информацию.

В соответствии с пунктом 2 Методических рекомендаций ФСБ России № 149/7/2/6-432 от 31.03.2015, при передаче персональных данных по каналам связи, не защищённым от перехвата, необходимо использование средств криптографической защиты информации (далее — СКЗИ).

Кроме того, в ИС «Бан-ID» осуществляется хранение персональных данных на несъёмных машинных носителях информации (жёсткие диски серверов и АРМ). Несанкционированный доступ к указанным носителям со стороны нарушителя не может быть исключен с помощью некриптографических методов и способов (при физическом доступе к оборудованию), что также является основанием для использования СКЗИ.

Таким образом, использование СКЗИ для обеспечения безопасности персональных данных, обрабатываемых в ИС «Бан-ID», является актуальным и обязательным.

При этом необходимо учитывать следующее:

- криптографическая защита персональных данных может быть обеспечена при условии отсутствия возможности несанкционированного доступа нарушителя к ключевой информации СКЗИ;

- СКЗИ штатно функционируют совместно с техническими и программными средствами, которые способны повлиять на выполнение предъявляемых к СКЗИ требований и которые образуют среду функционирования СКЗИ (далее — СФ);

- СКЗИ не предназначены для защиты информации от действий, выполняемых в рамках предоставленных субъекту действий полномочий (СКЗИ не предназначены для защиты персональных данных от раскрытия лицами, которым предоставлено право на доступ к этой информации);

- СКЗИ обеспечивают защиту информации при условии соблюдения требований эксплуатационно-технической документации на СКЗИ и требований действующих нормативных правовых документов в области реализации и эксплуатации СКЗИ;

- для обеспечения безопасности персональных данных при их обработке в ИС «Бан-ID» должны использоваться СКЗИ, прошедшие в установленном порядке процедуру оценки соответствия (сертифицированные);

- СКЗИ являются как средством защиты персональных данных, так и объектом защиты.

В соответствии со статьей 19 Федерального закона от 27.07.2006 № 152-ФЗ «О персональных данных», оператор ИС «Бан-ID» обязан принимать организационные и технические меры для защиты персональных данных, в том числе с использованием криптографических методов.

Согласно пункту 4 статьи 16 Федерального закона от 27.07.2006 № 149-ФЗ «Об информации, информационных технологиях и о защите информации», обладатель информации и оператор информационной системы обязаны обеспечить предотвращение несанкционированного доступа к информации и (или) передачи её лицам, не имеющим права на доступ к

информации. В условиях передачи данных по открытым каналам связи это требование может быть выполнено только с использованием СКЗИ.

10.2 Определение актуальности угроз, нейтрализуемых только с помощью СКЗИ

В соответствии с нормативными документами ФСБ России, к объектам защиты в ИС «Бан-ID», требующим криптографической защиты, относятся:

1. СКЗИ;
2. среда функционирования СКЗИ (СФ);
3. информация, относящаяся к криптографической защите персональных данных, включая ключевую, парольную и аутентифицирующую информацию СКЗИ;
4. документы, дела, журналы, технические документы, рабочие материалы и т.п., в которых отражена защищаемая информация, относящаяся к ИС «Бан-ID» и её криптографической защите, включая документацию на СКЗИ и на технические и программные компоненты СФ;
5. носители защищаемой информации, используемые в ИС «Бан-ID» в процессе криптографической защиты персональных данных, носители ключевой, парольной и аутентифицирующей информации СКЗИ и порядок доступа к ним;
6. используемые ИС «Бан-ID» каналы (линии) связи, включая кабельные системы (каналы связи между сегментами офиса Оператора и стадионов, организованные через сеть «Интернет»);
7. помещения, в которых находятся ресурсы ИС «Бан-ID», имеющие отношение к криптографической защите персональных данных.

В соответствии с нормативными документами ФСБ России, все физические лица, имеющие доступ к техническим и программным средствам ИС «Бан-ID», разделяются на следующие категории:

- лица, имеющие право постоянного доступа в контролируемую зону (далее — КЗ) ИС «Бан-ID» (сотрудники Оператора, имеющие доступ к ИС, зарегистрированные пользователи, обслуживающий персонал);
- лица, имеющие право разового доступа в КЗ ИС «Бан-ID» (посетители, лица, осуществляющие ремонт, обслуживание и сопровождение программных, технических и программно-технических средств ИС, в том числе средств защиты информации);
- привилегированные внутренние пользователи ИС «Бан-ID» (системные администраторы, администраторы информационной безопасности);
- внешние источники атак.

Все потенциальные нарушители подразделяются на:

- внешних нарушителей, не имеющих доступа к ИС «Бан-ID» и осуществляющих атаки из-за пределов КЗ;
- внутренних нарушителей, осуществляющих атаки, находясь в пределах КЗ ИС «Бан-ID», включая пользователей ИС, и реализующих угрозы непосредственно в ИС.

Привилегированные внутренние пользователи — члены группы администраторов, являются особо доверенными лицами, которые осуществляют обслуживание технических и программных средств СКЗИ и СФ, включая их настройку, конфигурирование и распределение ключевой документации между непривилегированными внутренними пользователями.

К их числу относятся ответственный за обеспечение безопасности информации в ИС «Бан-ID» и ответственный пользователь СКЗИ.

Предположения об отнесении категории физических лиц к потенциальным источникам атак представлены в таблице 29.

Таблица 29 — Потенциальные источники атак

Категория физических лиц	Предположение об отнесении категории физических лиц к потенциальным источникам атак	Обоснование предположения об отнесении категории физических лиц к потенциальным источникам атак
Лица, имеющие право постоянного доступа в КЗ ИС «Бан-ID»	Да	- обслуживающий персонал и лица, обеспечивающие функционирование ИС, имеют возможность находиться в помещениях, где расположена ИС, в отсутствие пользователей ИС; - работа внутренних пользователей ИС регламентирована.
Лица, имеющие право разового доступа в КЗ ИС «Бан-ID»	Да	- ремонт, обслуживание и сопровождение программных, технических и

		программно-технических средств ИС, в том числе СЗИ, выполняется доверенными лицами, с выполнением мер по обеспечению безопасности информации; - в помещениях, в которых происходит обработка информации, возможно нахождение посторонних лиц; - обслуживающий персонал и лица, обеспечивающие функционирование ИС, имеют возможность находиться в помещениях, где расположена ИС, в отсутствие пользователей ИС.
Привилегированные внутренние пользователи ИС «Бан-ID»	Нет	- ремонт, обслуживание и сопровождение программных, технических и программно-

		технических средств ИС, в том числе СЗИ, выполняется доверенными лицами, с выполнением мер по обеспечению безопасности информации; - ответственный за обеспечение безопасности информации, ответственный пользователь СКЗИ назначаются из числа особо доверенных лиц.
Внешние субъекты (физические лица)	Да	- имеют возможность осуществлять создание способов реализации угроз, подготовку и реализацию угроз информационной безопасности только за пределами КЗ.

На основании исходных данных об ИС «Бан-ID», объектах защиты и источниках атак, в соответствии с Методическими рекомендациями ФСБ России № 149/7/2/6-432 от 31.03.2015, определены обобщенные возможности источников атак, которые описаны в таблице 30.

Таблица 30 — Обобщенные возможности источников атак

№	Обобщенные возможности источников атак	Предположение о возможности источников атак
1	Возможность самостоятельно осуществлять создание способов атак, подготовку и проведение атак только за пределами КЗ	Да
2	Возможность самостоятельно осуществлять создание способов атак, подготовку и проведение атак в пределах КЗ, но без физического доступа к аппаратным средствам, на которых реализованы СКЗИ и среда их функционирования	Да
3	Возможность самостоятельно осуществлять создание способов атак, подготовку и проведение атак в пределах КЗ с физическим доступом к аппаратным средствам, на которых реализованы СКЗИ и среда их функционирования	Да
4	Возможность привлекать специалистов, имеющих опыт разработки и анализа СКЗИ (включая специалистов в области анализа сигналов линейной передачи и сигналов побочного электромагнитного излучения и наводок СКЗИ)	Нет
5	Возможность привлекать специалистов, имеющих опыт разработки и анализа СКЗИ (включая специалистов в области использования для реализации атак недокументированных	Нет

	возможностей прикладного программного обеспечения)	
6	Возможность привлекать специалистов, имеющих опыт разработки и анализа СКЗИ (включая специалистов в области использования для реализации атак недокументированных возможностей аппаратного и программного компонентов среды функционирования СКЗИ)	Нет

Анализ уточнённых возможностей нарушителей и направления атак, исходя из обобщённых возможностей источников атак, приведён в таблице 31.

Таблица 31 — Уточнённые возможности нарушителей и направления атак

№	Уточнённые возможности нарушителей и направления атак (соответствующие актуальные угрозы)	Актуальность использования (применения) для построения и реализации атак	Обоснование
1.1	Проведение атаки при нахождении в пределах КЗ	Актуально	
1.2	Проведение атак на этапе эксплуатации СКЗИ на следующие объекты: - документацию на СКЗИ и компоненты СФ; - помещения, в которых находится совокупность программных и технических элементов систем обработки данных, способных функционировать самостоятельно или в составе других систем (СВТ), на которых реализованы СКЗИ и СФ	Неактуально	- ответственный пользователь СКЗИ назначается из числа особо доверенных лиц; - документация на СКЗИ хранится у ответственного пользователя СКЗИ в металлическом сейфе (шкафу); - помещения, в которых располагаются документация на СКЗИ, СКЗИ и СФ, оснащены входными дверьми с замками; - обеспечивается

			постоянное закрытие дверей помещений на замок и их открытие только для санкционированного прохода; - утверждён перечень лиц, имеющих право доступа в помещения.
1.3	Получение в рамках предоставленных полномочий, а также в результате наблюдений следующей информации: - сведений о физических мерах защиты объектов, в которых размещены ресурсы ИС; - сведений о мерах по обеспечению КЗ объектов, в которых размещены ресурсы ИС; - сведений о мерах по разграничению доступа в помещения, в которых находятся СВТ, на которых реализованы СКЗИ и СФ	Неактуально	- сведения о физических мерах защиты объектов доступны ответственному за обеспечение безопасности информации, администраторам ИС; - ответственный пользователь СКЗИ назначается из числа особо доверенных лиц; - ответственный за обеспечение безопасности информации,

			администраторы ИС назначаются из числа особо доверенных лиц.
1.4	Использование штатных средств ИС «Бан-ID», ограниченные мерами, реализованными в ИС, в которой используется СКЗИ, и направленными на предотвращение и пресечение несанкционированных действий	Неактуально	- ответственный пользователь СКЗИ назначается из числа особо доверенных лиц; - ответственный за обеспечение безопасности информации, администраторы ИС назначаются из числа особо доверенных лиц; - работа пользователей ИС регламентирована; - помещения, в которых располагаются СВТ, на которых располагаются СКЗИ и СФ, оснащены входными дверьми с замками; -

			сотрудники проинформированы об ответственности за несоблюдение правил обеспечения безопасности информации.
2.1	Физический доступ к СВТ, на которых реализованы СКЗИ и СФ	Актуально	- Практическая реализация атак с физическим доступом существенно затруднена организационными мерами контроля доступа, однако полностью не исключается доступ; - помещения, в которых располагаются СВТ, оснащены входными дверьми с замками.

2.2	Возможность воздействовать на аппаратные компоненты СКЗИ и СФ, ограниченная мерами, реализованными в ИС «Бан-ID», и направленными на предотвращение и пресечение несанкционированных действий	Актуально	- - Практическая реализация атак с физическим доступом существенно затруднена организационными мерами контроля доступа, однако полностью не исключается доступ; - ответственный пользователь СКЗИ назначается из числа особо доверенных лиц; - помещения, в которых располагаются документация на СКЗИ, СКЗИ и СФ, оснащены входными дверьми с замками; - обслуживающий персонал и лица, обеспечивающие функционирование ИС, не
-----	---	------------------	---

			имеют возможность находиться в помещениях, где расположены СКЗИ и СФ.
3.1	Создание способов, подготовка и проведение атак с привлечением специалистов в области анализа сигналов, сопровождающих функционирование СКЗИ и СФ, и в области использования для реализации атак недокументированных (недекларированных) возможностей прикладного ПО	Неактуально	- не осуществляется обработка сведений, составляющих государственную тайну; - высокая стоимость и сложность подготовки реализации возможности.
3.2	Проведение лабораторных исследований СКЗИ, используемых вне КЗ, ограниченное мерами, реализованными в ИС «Бан-ID», и направленными на предотвращение и пресечение несанкционированных действий	Неактуально	- не осуществляется обработка сведений, составляющих государственную тайну; - высокая стоимость и сложность подготовки реализации возможности.

3.3	Проведение работ по созданию способов и средств атак в научно-исследовательских центрах, специализирующихся в области разработки и анализа СКЗИ и СФ	Неактуально	- не осуществляется обработка сведений, составляющих государственную тайну; - высокая стоимость и сложность подготовки реализации возможности.
4.1	Создание способов, подготовка и проведение атак с привлечением специалистов в области использования для реализации атак недокументированных (недекларированных) возможностей системного ПО	Неактуально	- не осуществляется обработка сведений, составляющих государственную тайну; - высокая стоимость и сложность подготовки реализации возможности.
4.2	Возможность располагать сведениями, содержащимися в конструкторской документации на аппаратные и программные компоненты СФ	Неактуально	- не осуществляется обработка сведений, составляющих государственную тайну.

4.3	Возможность воздействовать на любые компоненты СКЗИ и СФ	Неактуально	- не осуществляется обработка сведений, составляющих государственную тайну.
-----	--	--------------------	---

В соответствии с изложенными выше предположениями о наличии возможностей у нарушителей на проведение атак и в соответствии с Приказом ФСБ России от 10 июля 2014 г. № 378 «Об утверждении Состав и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных с использованием средств криптографической защиты информации, необходимых для выполнения установленных Правительством Российской Федерации требований к защите персональных данных для каждого из уровней защищённости», а также с учётом:

- уровня защищённости персональных данных (3-й уровень по Постановлению Правительства РФ № 1119);
- типа актуальных угроз (3-й тип угроз);
- наличия у нарушителей возможности проведения атак при нахождении в пределах контролируемой зоны и с физическим доступом к аппаратным средствам (возможности 1.1, 2.1, 2.2),

Для реализации требований рекомендуется применение сертифицированных средств криптографической защиты не ниже класса КС2

11 Выводы

В результате разработки модели угроз и нарушителей безопасности информации, обрабатываемой в ИС «Бан-ID», был определён перечень актуальных угроз.

Каждая из угроз безопасности, включённых в перечень, должна быть нейтрализована с помощью проведения мероприятий по созданию подсистемы защиты информации, путем выбора мер защиты, нейтрализующих данные угрозы, и подбора соответствующих сертифицированных средств защиты информации.